

编 号:

版 本 号: 1.1.0

内部资料 严禁外泄



---

中电信量子集团

量子密信开发者后台用户操作手册

---

## 修订记录

| 编号 | 章节名称 | 修订内容简述       | 修订日期       | 修订后版本号 | 修订人 | 批准人 |
|----|------|--------------|------------|--------|-----|-----|
| 1  | 所有   | 初始版本         | 2025-12-30 | V1.0.0 | 尤冠博 | 黄宗魁 |
| 2  | 所有   | 新增【开发内部应用】模块 | 2026-02-28 | V1.1.0 | 尤冠博 | 黄宗魁 |
| 3  |      |              |            |        |     |     |

## 目录

|                       |    |
|-----------------------|----|
| 1. 目的                 | 5  |
| 2. 适用范围               | 5  |
| 3. 平台简介               | 5  |
| 4. 页面介绍               | 6  |
| 4.1 登录                | 6  |
| 4.1.1 账号密码登录          | 6  |
| 4.1.2 忘记密码            | 7  |
| 4.1.3 切换公司            | 8  |
| 4.1.4 修改密码            | 8  |
| 4.1.5 退出登录            | 9  |
| 4.2 我的应用              | 10 |
| 4.2.1 自建应用            | 11 |
| 4.2.2 新建应用            | 12 |
| 4.2.3 查询应用            | 12 |
| 4.2.4 查看应用            | 13 |
| 4.2.5 管理应用            | 13 |
| 4.2.6 商店应用            | 21 |
| 4.2.7 SDK 应用          | 21 |
| 4.3 机器人列表             | 22 |
| 4.3.1 应用机器人详情         | 23 |
| 4.3.2 webhook 推送机器人详情 | 23 |
| 4.3.3 webhook 会话机器人详情 | 24 |
| 4.4 开发者管理             | 25 |
| 4.4.1 开发者列表           | 25 |
| 4.4.2 查询开发者           | 25 |
| 4.4.3 添加开发者           | 26 |
| 4.5 管理员列表             | 26 |
| 4.5.1 查询管理员           | 27 |
| 4.5.2 添加管理员           | 27 |
| 5. 开发内部应用             | 28 |
| 5.1 开发流程              | 28 |
| 5.1.1 开发步骤            | 28 |
| 5.1.2 应用部署与测试         | 44 |
| 5.1.3 应用自检表           | 45 |
| 5.1.4 安全运营            | 46 |
| 5.2 开发网页应用            | 47 |

---

|                             |    |
|-----------------------------|----|
| 5.2.1 网页应用开发指南 .....        | 47 |
| 5.2.2 获取 access_token ..... | 55 |
| 5.2.3 应用授权登录 .....          | 57 |

## 1.目的

本用户操作手册旨在系统性地介绍量子密信开发者后台的功能特性，为用户提供清晰易懂的操作指引，助力用户实现高效的系统操作。用户可根据自身需求查阅对应功能模块的操作说明，并参考手册中提供的常见问题解决方案。

## 2.适用范围

本文档适用于所有与本项目有关的软件开发阶段及其相关人员，其中包括：客户代表、项目经理、技术开发人员、测试人员等。

## 3.平台简介

量子密信开发者后台，是量子密信面向入驻单位开放的应用开发与集成平台。

平台基于量子密信统一的账号体系、组织通讯录和消息通道能力，为单位内部开发者及授权服务商提供标准化的应用接入能力，支持将单位内部业务系统、工具服务和自动化能力，以应用或机器人的形式集成到量子密信客户端中。

通过开发者后台，单位可以：

- 将内部业务系统统一接入量子密信工作台
- 基于消息与事件机制，实现人与系统、系统与系统的协同
- 按需配置应用能力、权限范围与可见范围
- 对应用生命周期进行统一管理和持续迭代

当前平台仅支持单位自建应用的创建与发布，应用仅在单位内部使用。后续将逐步开放更多应用能力和应用形态。

## 4. 页面介绍

### 4.1 登录

#### 4.1.1 账号密码登录

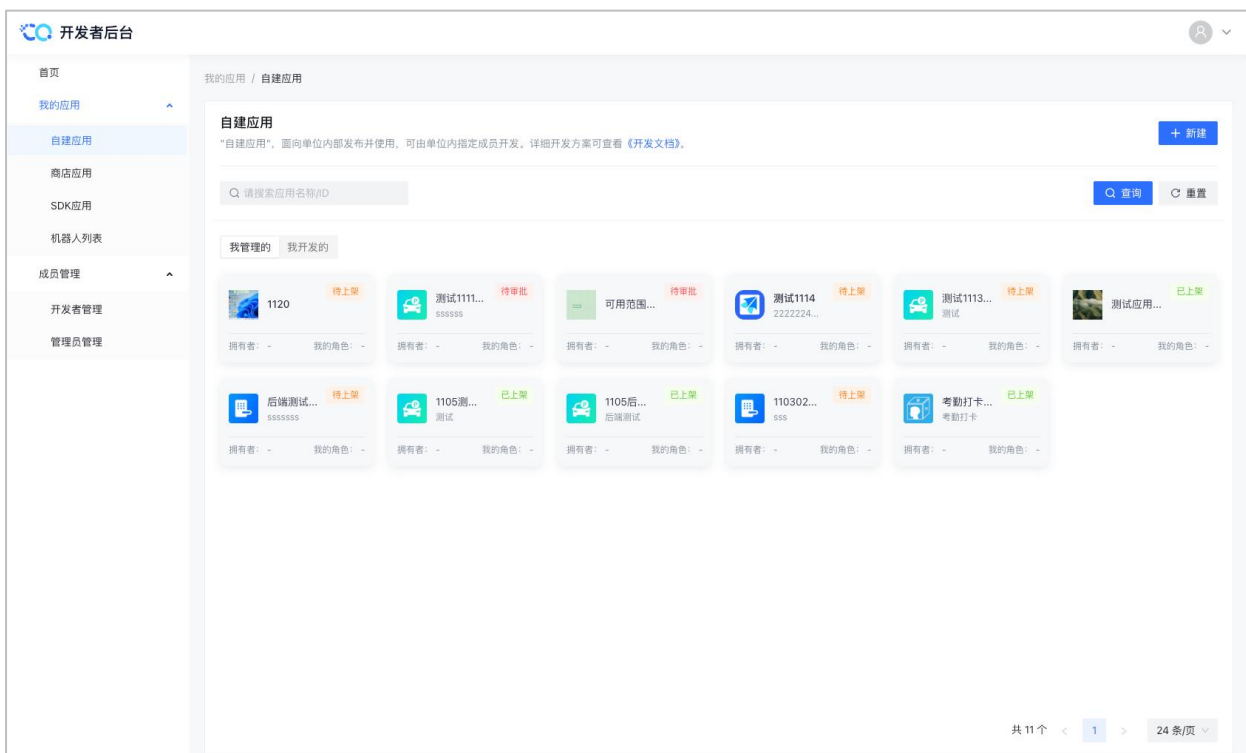
- 1、量子密信开发者后台地址：[https://dev-mixin.zdxyz.com/ctq\\_login/](https://dev-mixin.zdxyz.com/ctq_login/)
- 2、进入登录页面，开发者后台管理员、开发者用户输入正确的账号密码。



- 3、点击“登录”，进入组织单位选择页面（如果当前用户只有一个组织，则直接进入）。



4、选择需要访问的组织单位，进入开发者后台首页。



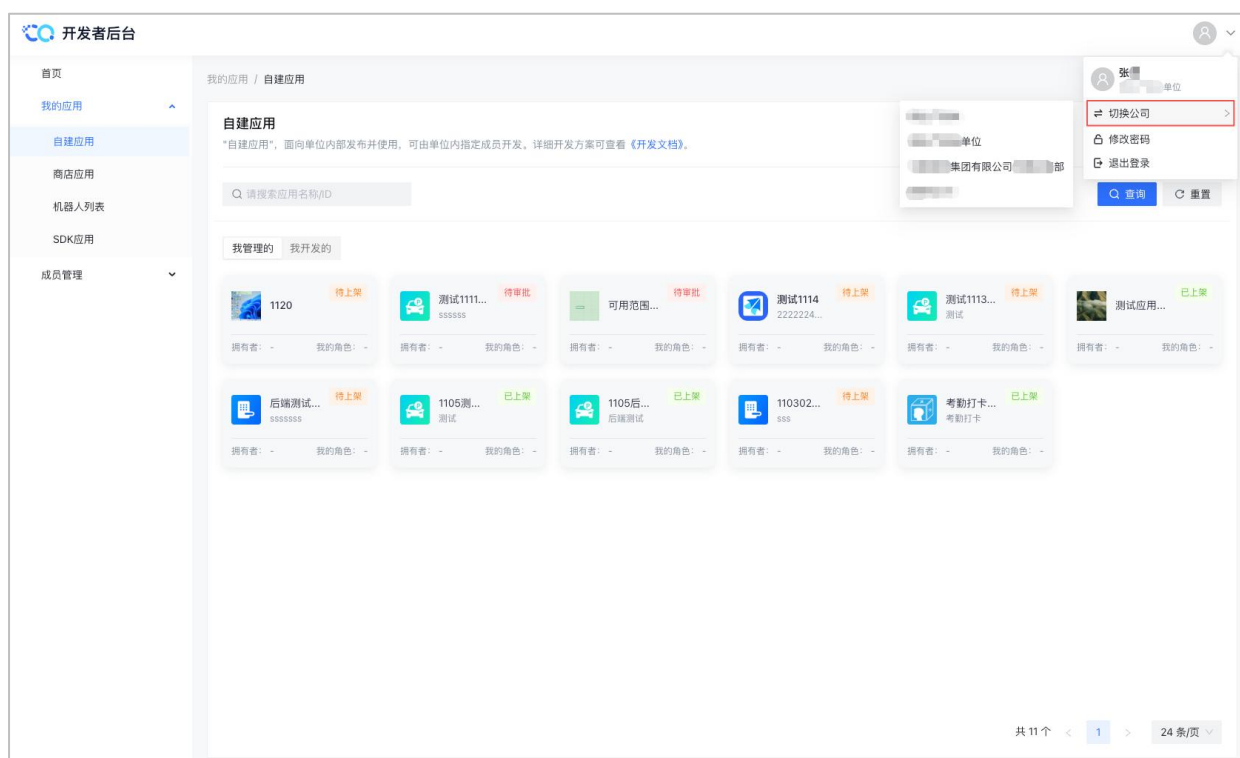
### 4.1.2 忘记密码

1、用户忘记登录密码时，可点击登录页“忘记密码”，重置登录密码。

- 2、进入重置密码页面，输入账号，点击“获取验证码”，提示“验证码发送成功”，系统自动发送短信验证码至登录账号手机号，再次获取验证码需等待 60s，验证码有效期 5 分钟。
- 3、正确输入接收到的短信验证码，输入“新密码”，输入“确认密码”并与“新密码”保持一致，密码需满足“”的设置规则。
- 4、点击确认，提示“密码重置成功”，系统自动跳转到登录页，执行“4.1.1 账号密码登录”步骤即可正常登录系统。

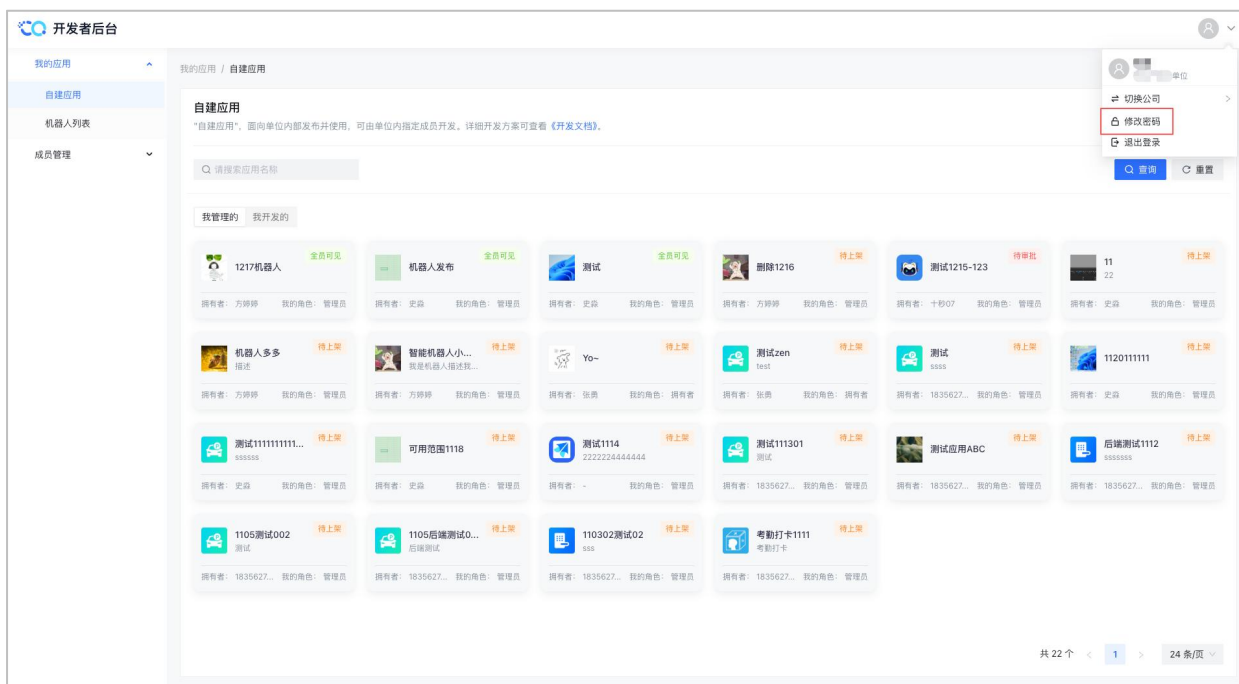
### 4.1.3 切换公司

- 1、登录成功的用户，可以在系统右上角“用户信息”中切换单位组织。

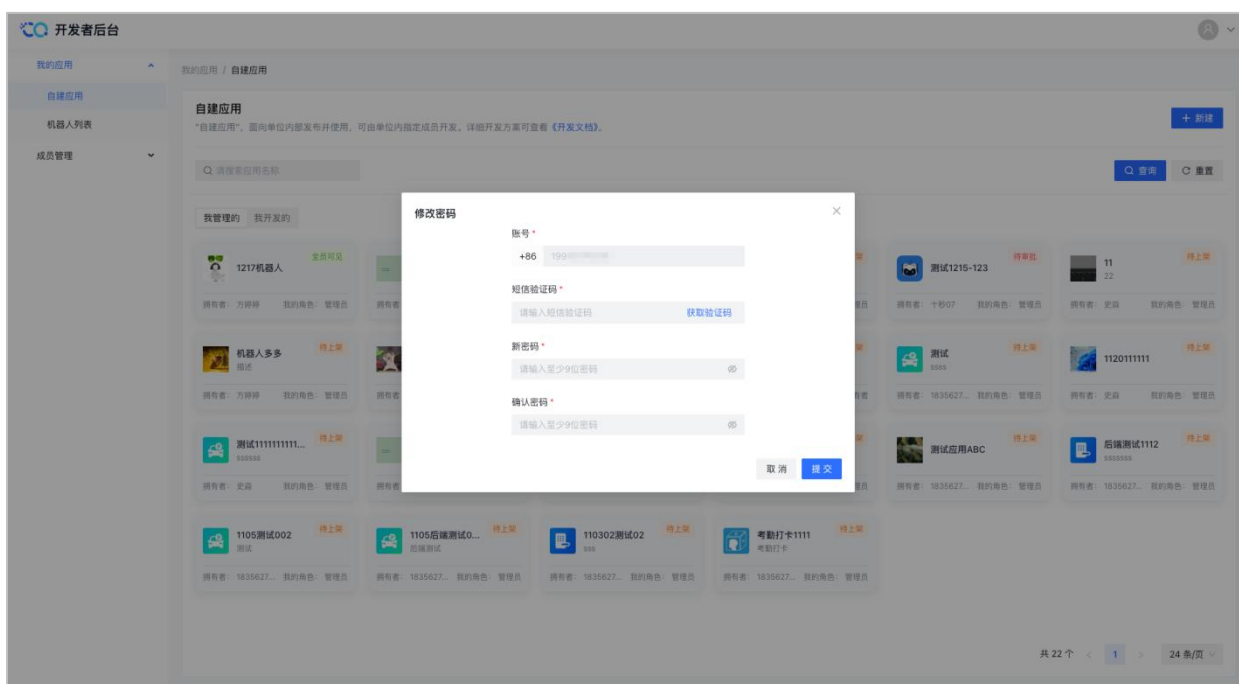


### 4.1.4 修改密码

- 1、登录成功的用户，可以在系统右上角“用户信息”中修改密码。



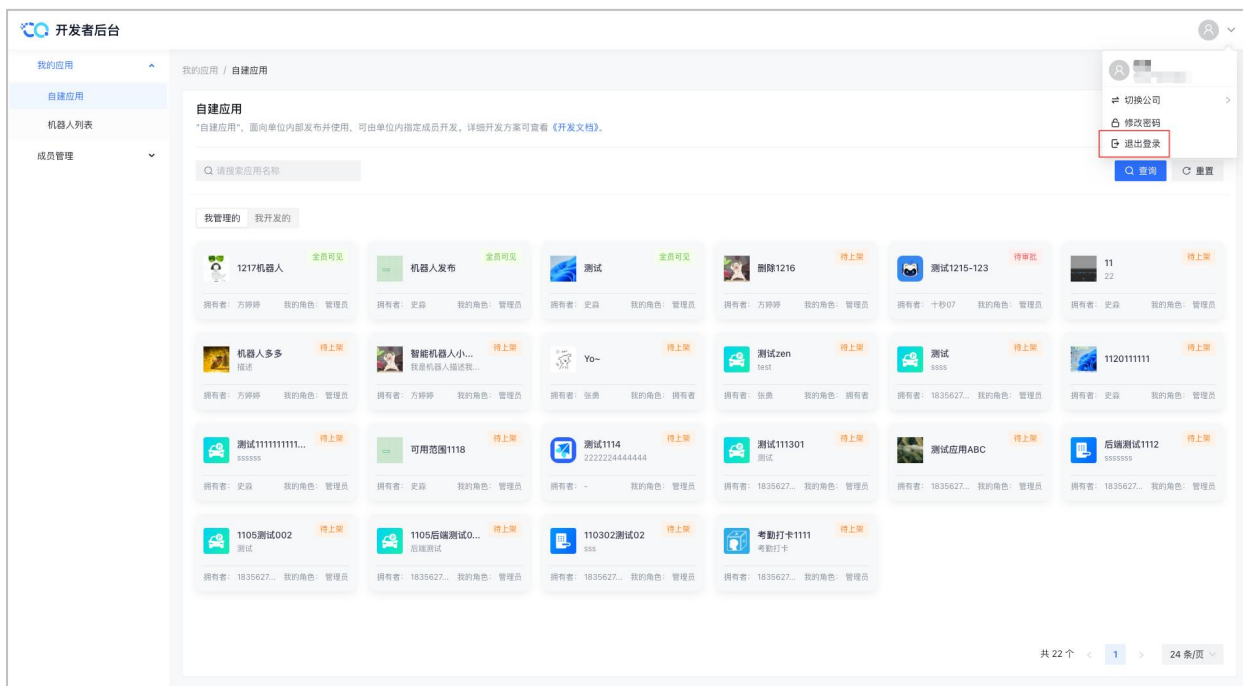
2、点击修改密码。



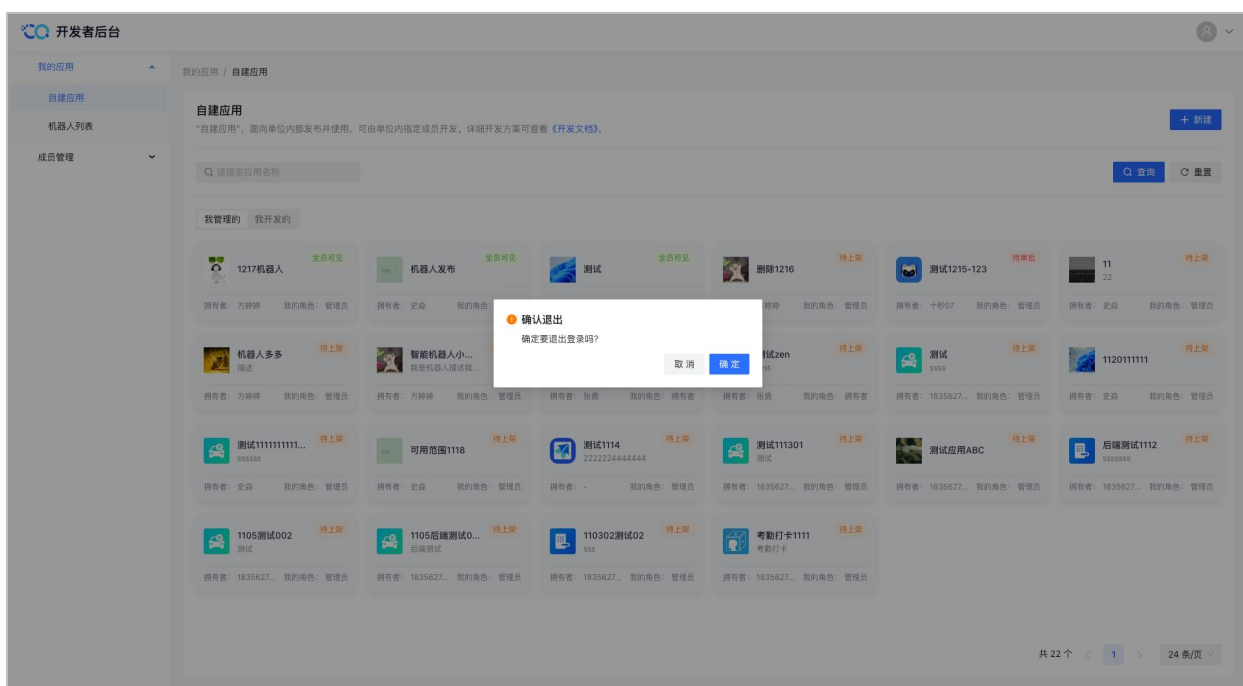
3、确认当前登录手机号，点击“获取验证码”，填写短信验证码，输入新密码，确认新密码。

## 4.1.5 退出登录

1、登录成功的用户，可以在系统右上角“用户信息”中退出登录。



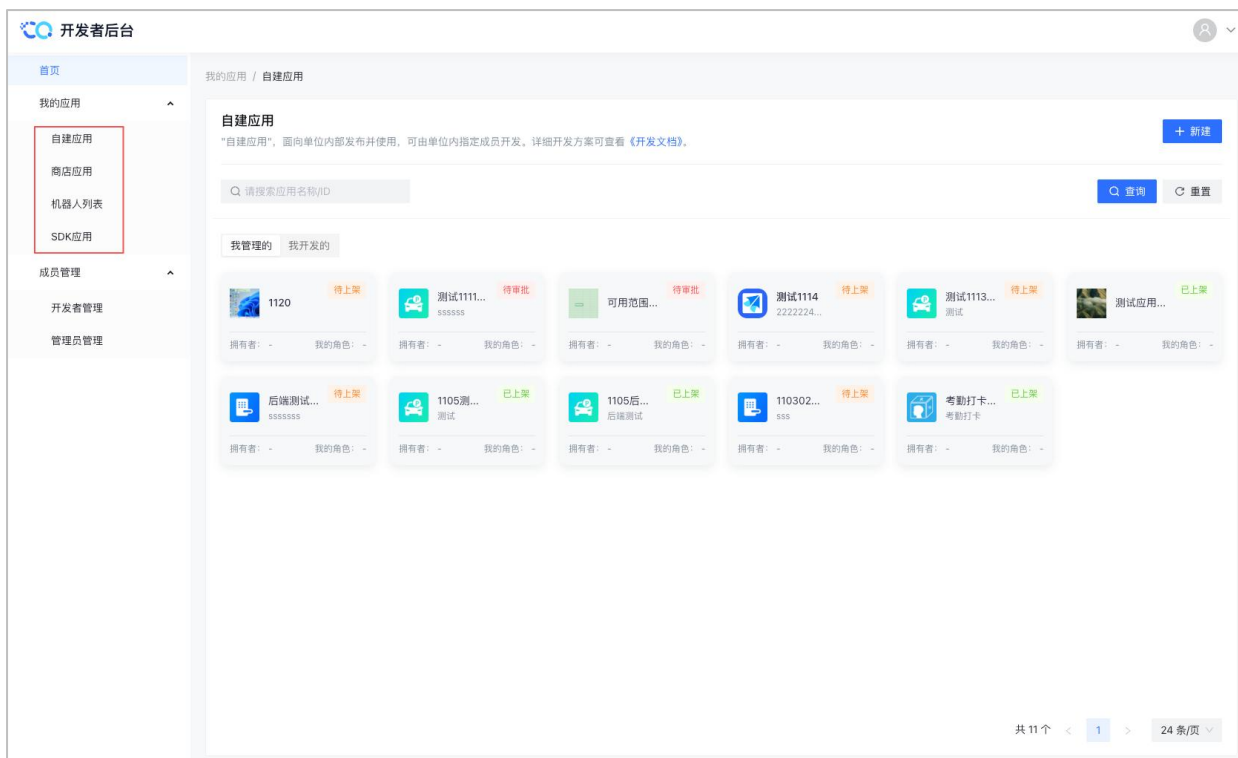
2、点击“退出登录”，弹窗提示是否确认退出登录。



3、点击“取消”，保留用户登录状态；点击“确定”，用户退出登录，系统返回登录页面。

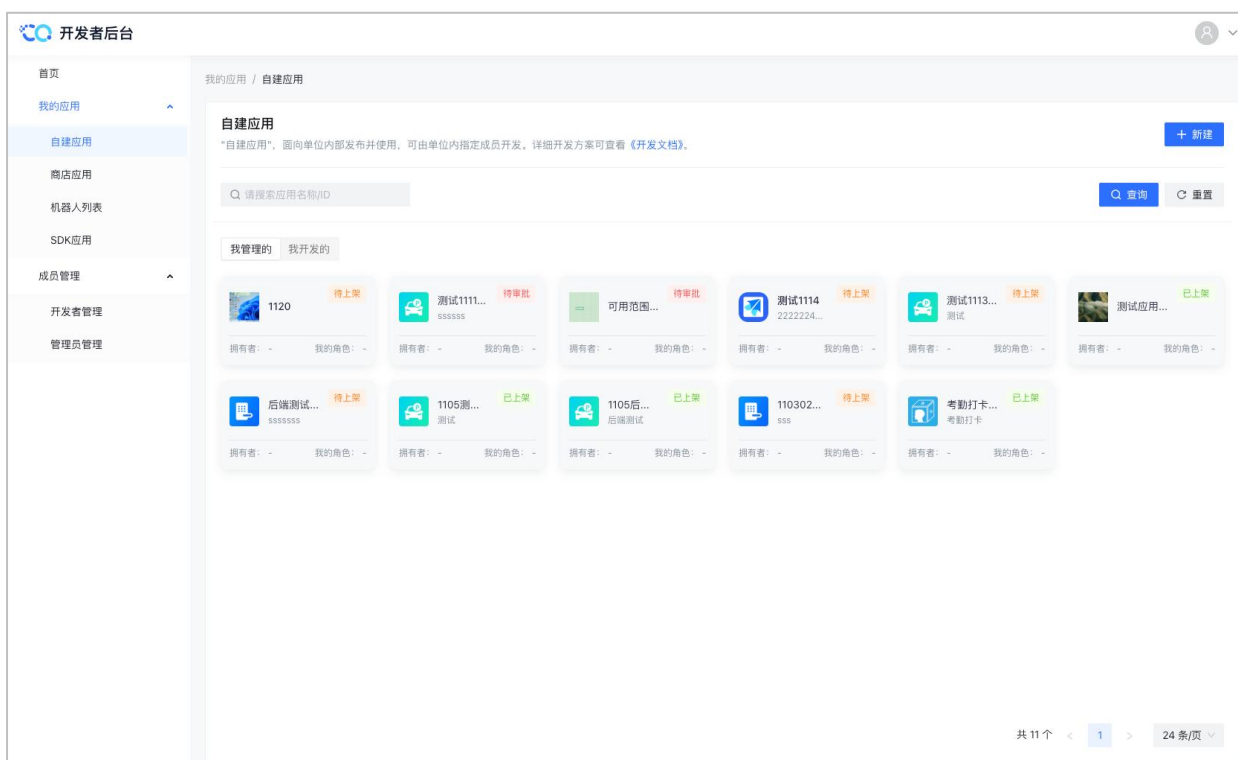
## 4.2 我的应用

有权限的用户登录本系统后，点击左侧菜单【我的应用】，回显子菜单【自建应用】、【商店应用】、【机器人列表】和【SDK 应用】。



## 4.2.1 自建应用

点击【自建应用】，进入量子密信开发者后台自建应用管理页面，列表展示当前用户管理和开发的应用。



## 4.2.2 新建应用

- 1、新建官方应用，弹框输入应用名称、描述和应用图标。



## 4.2.3 查询应用

- 1、在搜索框中输入应用名称，再点击右侧的【搜索】按钮，即可搜索出应用。





## 4.2.4 查看应用

- 1、鼠标移入应用卡片并点击，可进入应用详情页面查看应用。

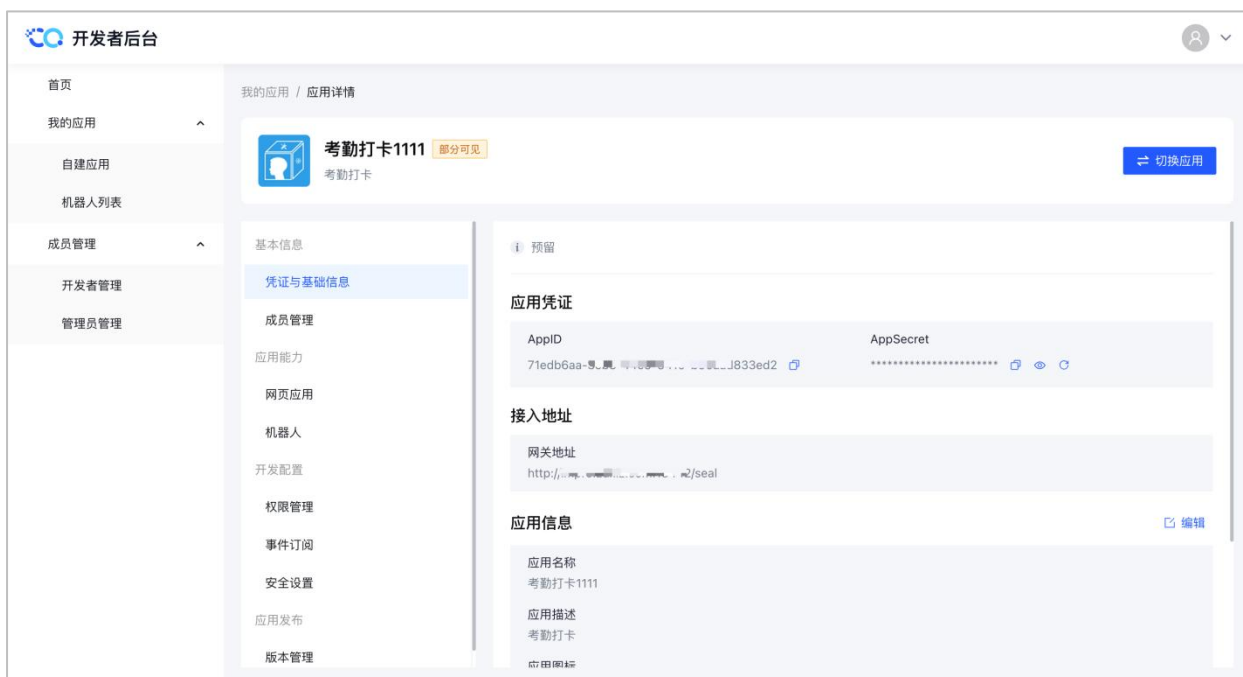


## 4.2.5 管理应用

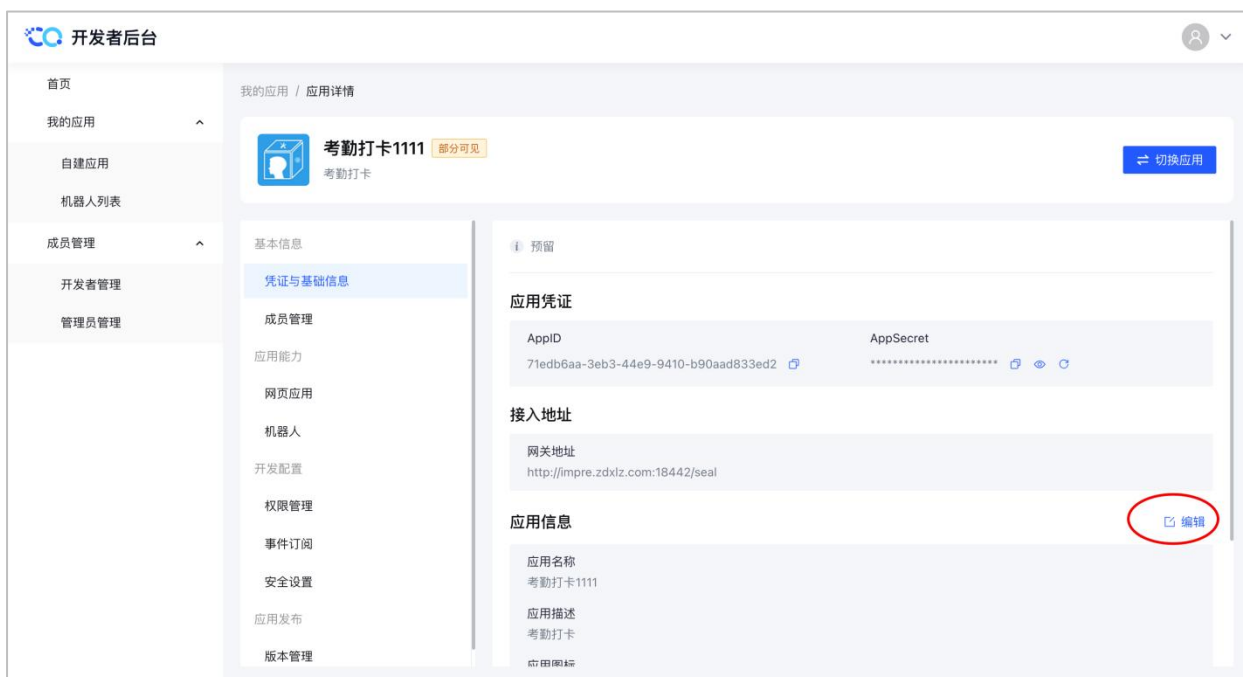
### 4.2.5.1 凭证与基础信息

- 1、在凭证与基础信息菜单中，可以复制将 AppID 和 AppSecret 复制至剪切板，可将

AppSecret 查看由脱敏展示变更为正常展示状态，或重置 AppSecret。



2、应用信息编辑：点击重新编辑应用基础信息，包括应用名称、应用描述、应用图标。



3、停用应用：停用后应用状态更新，且不在管理后台显示。

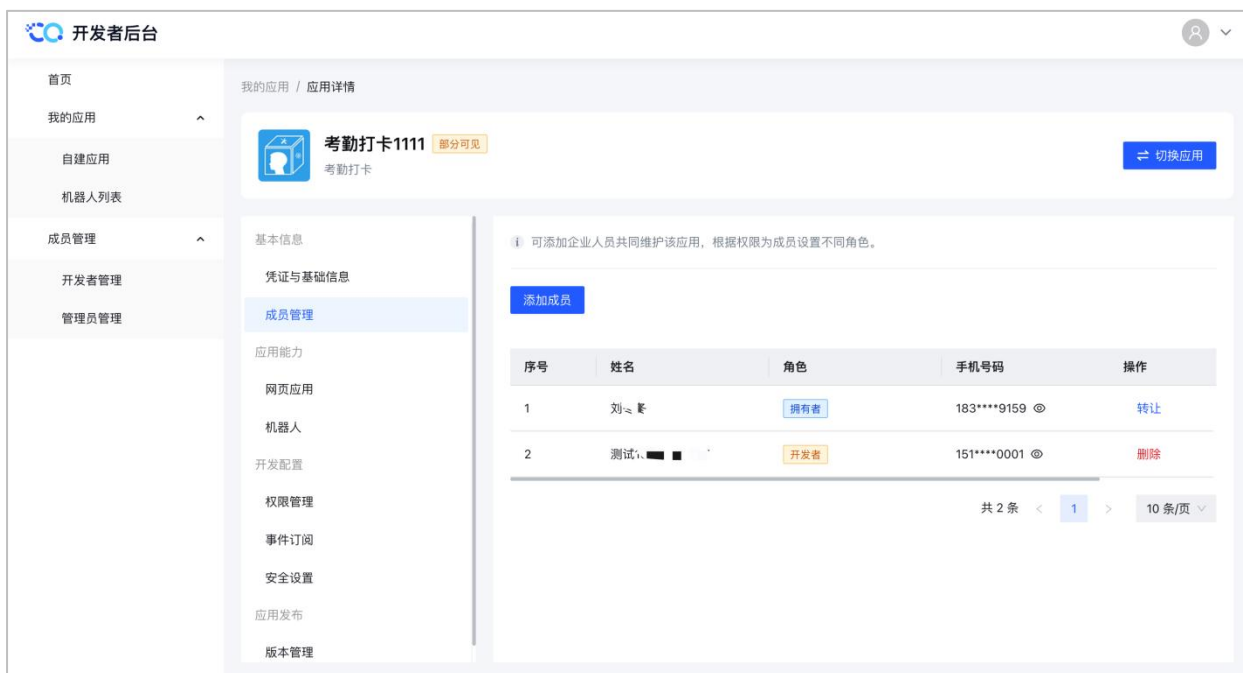
4、删除应用：需要先停用，再点击删除此应用，点击回到应用列表页。



#### 4.2.5.2 成员管理

在应用下的成员管理中，可以添加、删除应用成员，也可以转让拥有者。

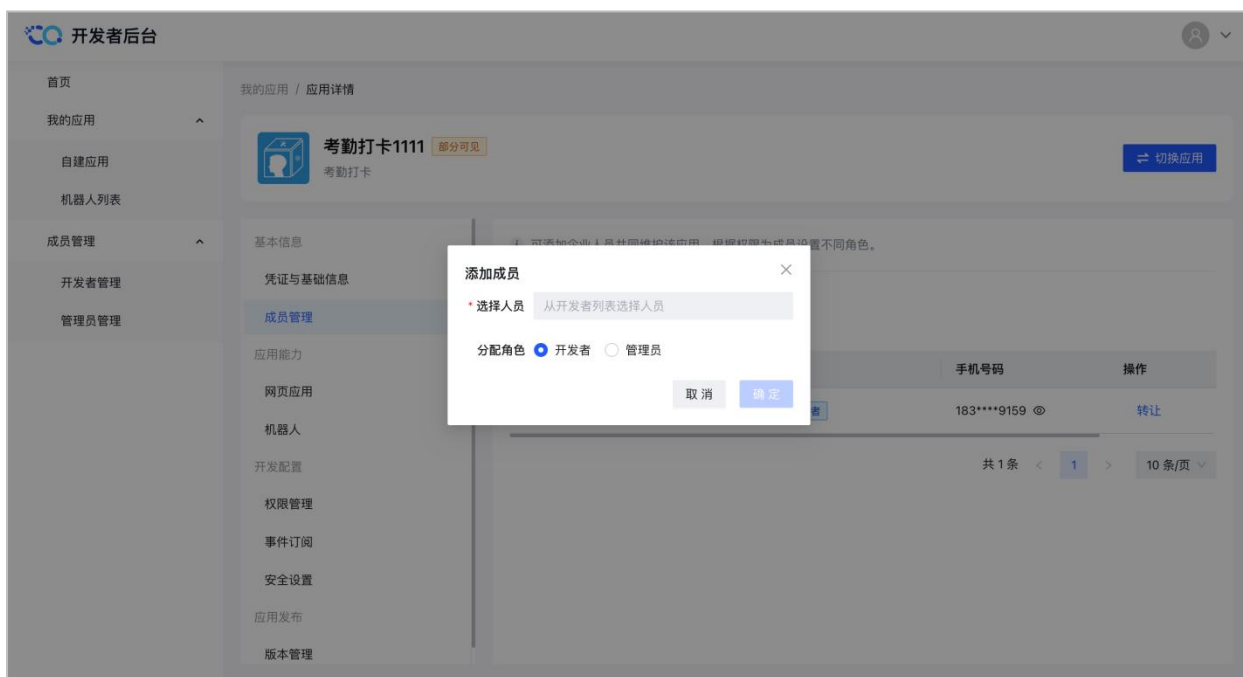
- 1、转让：转让应用的拥有人。
- 2、删除：从这个应用的开发者中移除这个用户。



3、添加成员可以添加应用开发者和管理员。

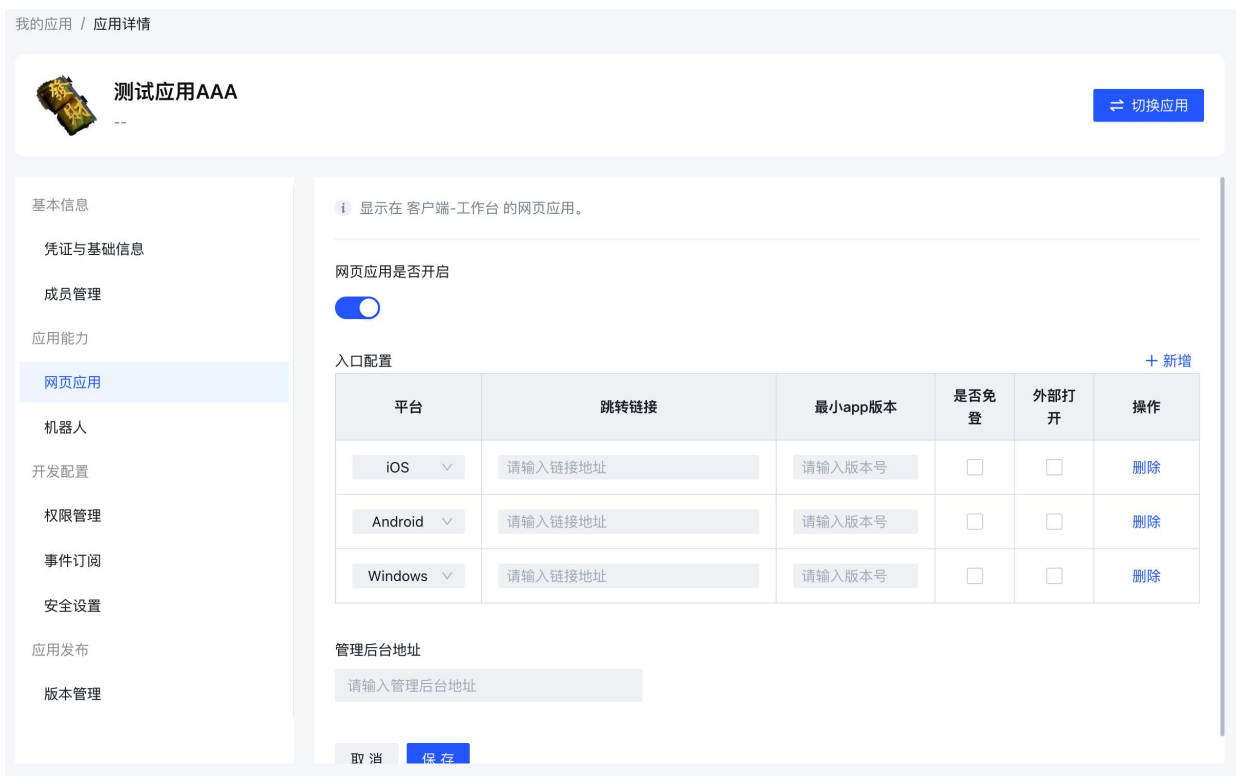
- a) 应用开发者：仅能调整和查看开发配置。

b) 应用管理员：具备发布应用的能力，不允许删除应用。



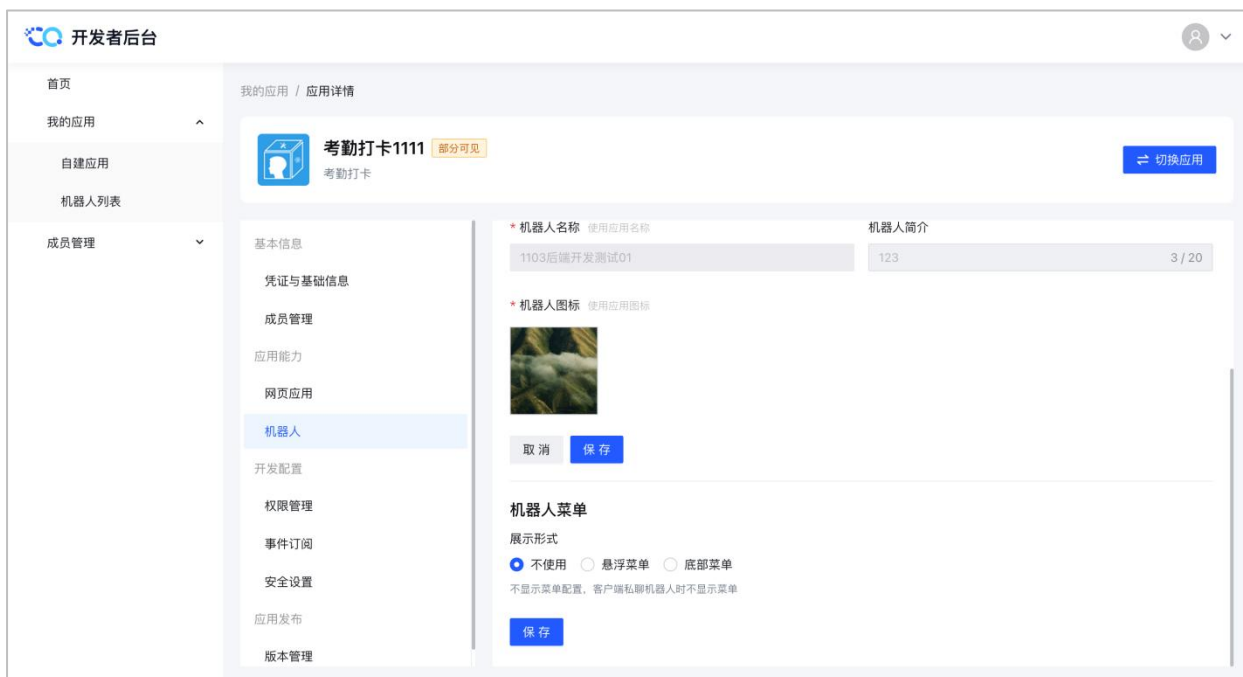
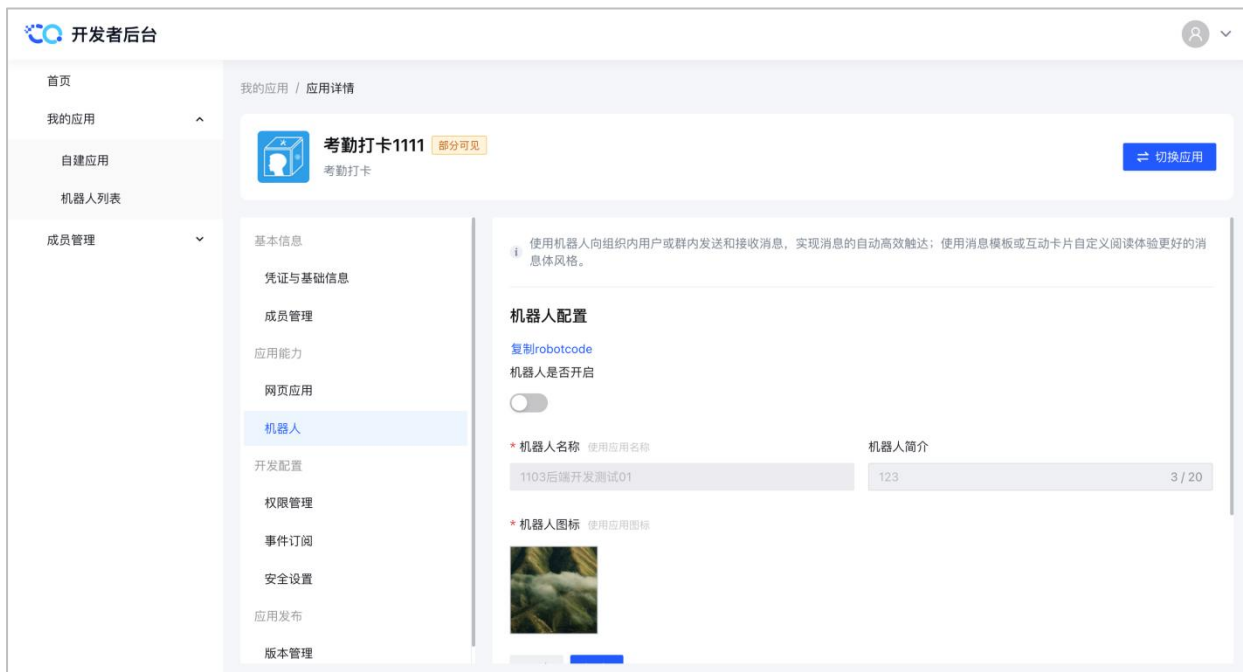
#### 4.2.5.3 网页应用

可开启或关闭网页应用。开启后，需要配置入口和管理后台地址。



#### 4.2.5.4 机器人

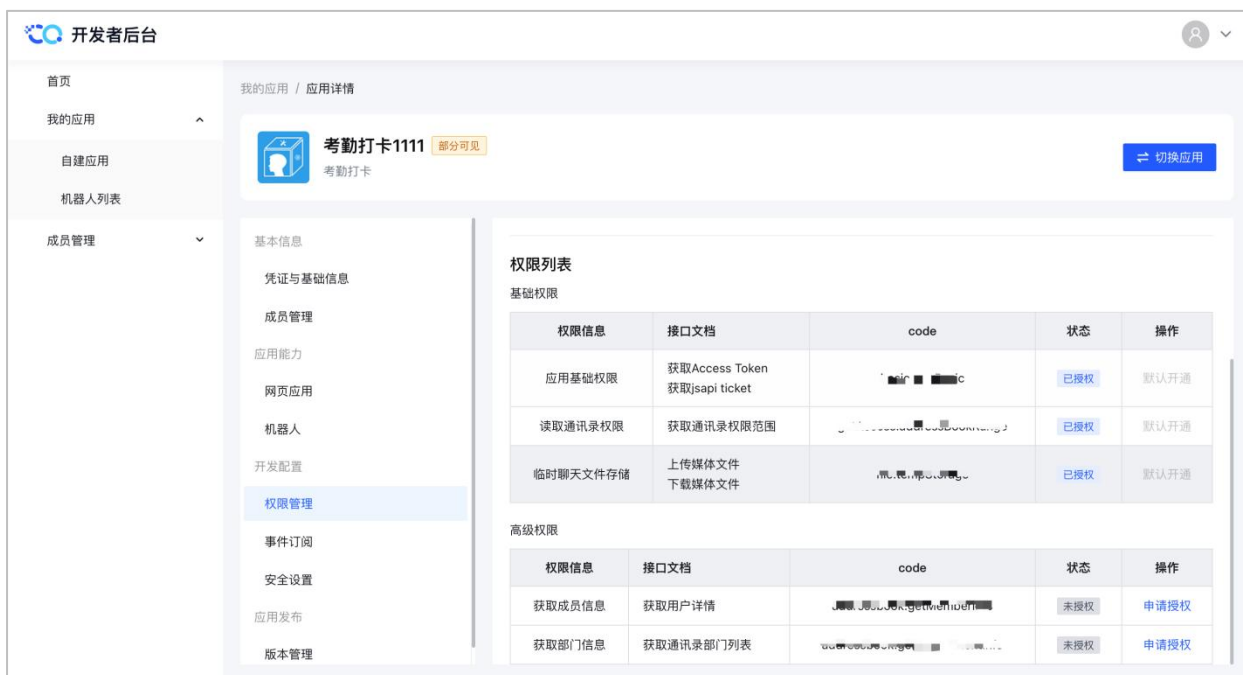
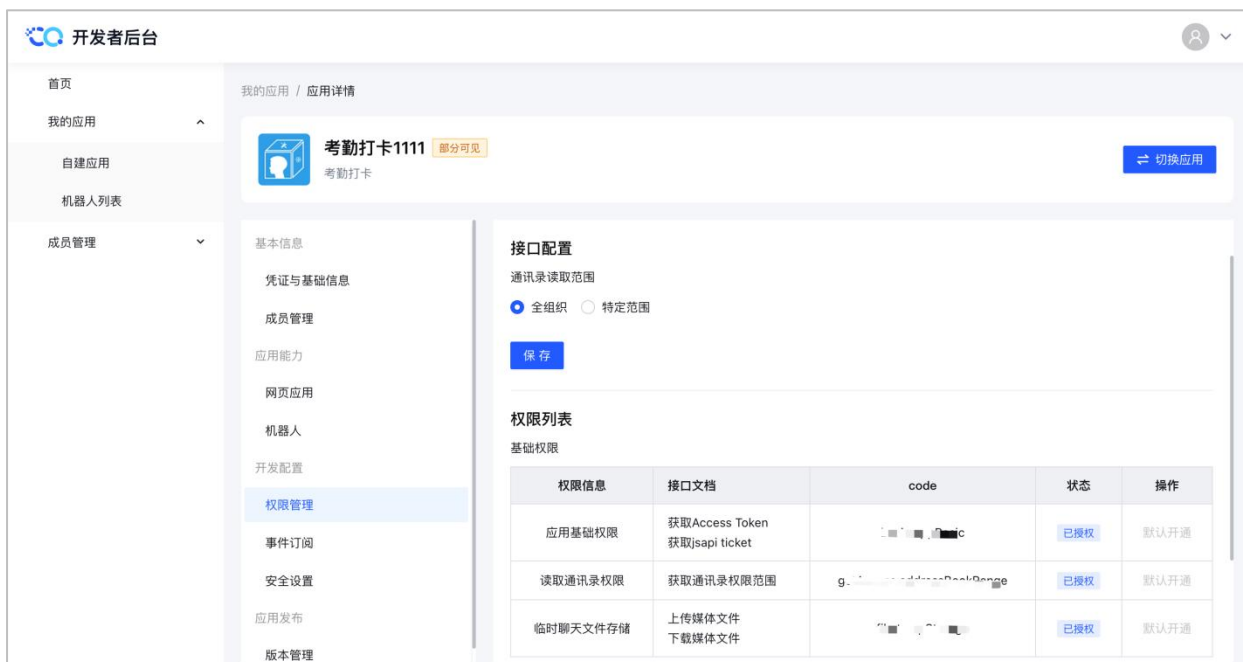
可开启或关闭网页应用。开启后，需要配置机器人信息。



#### 4.2.5.5 权限管理

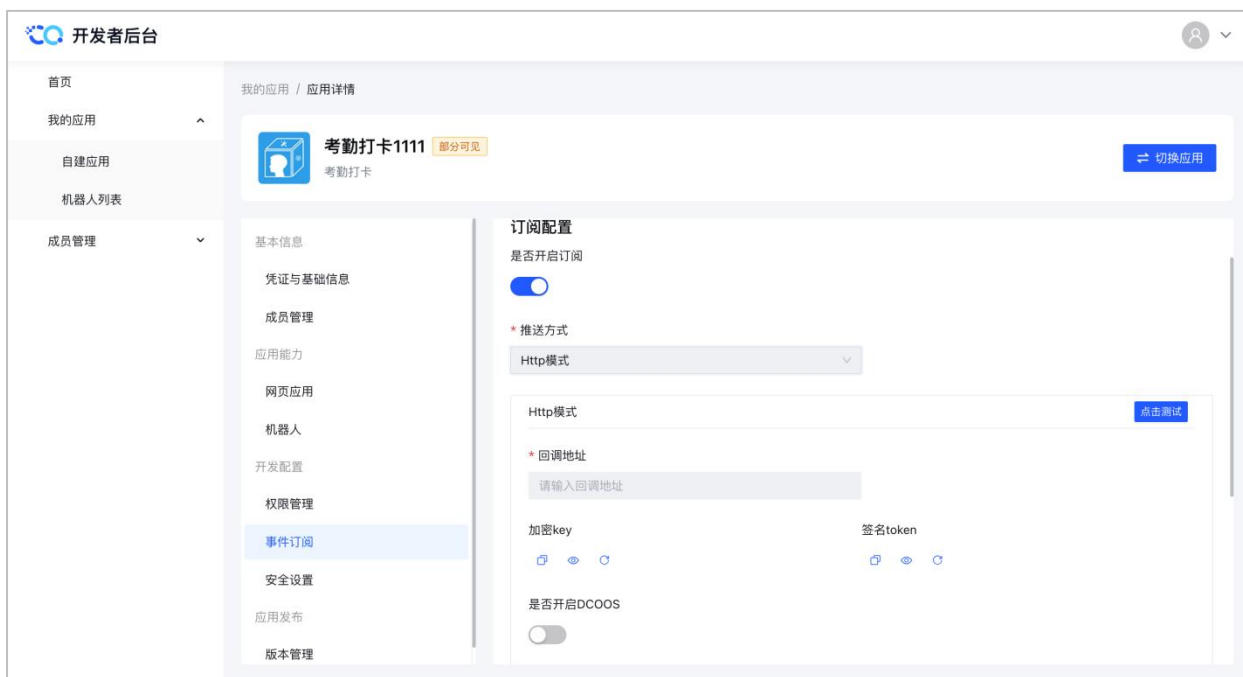
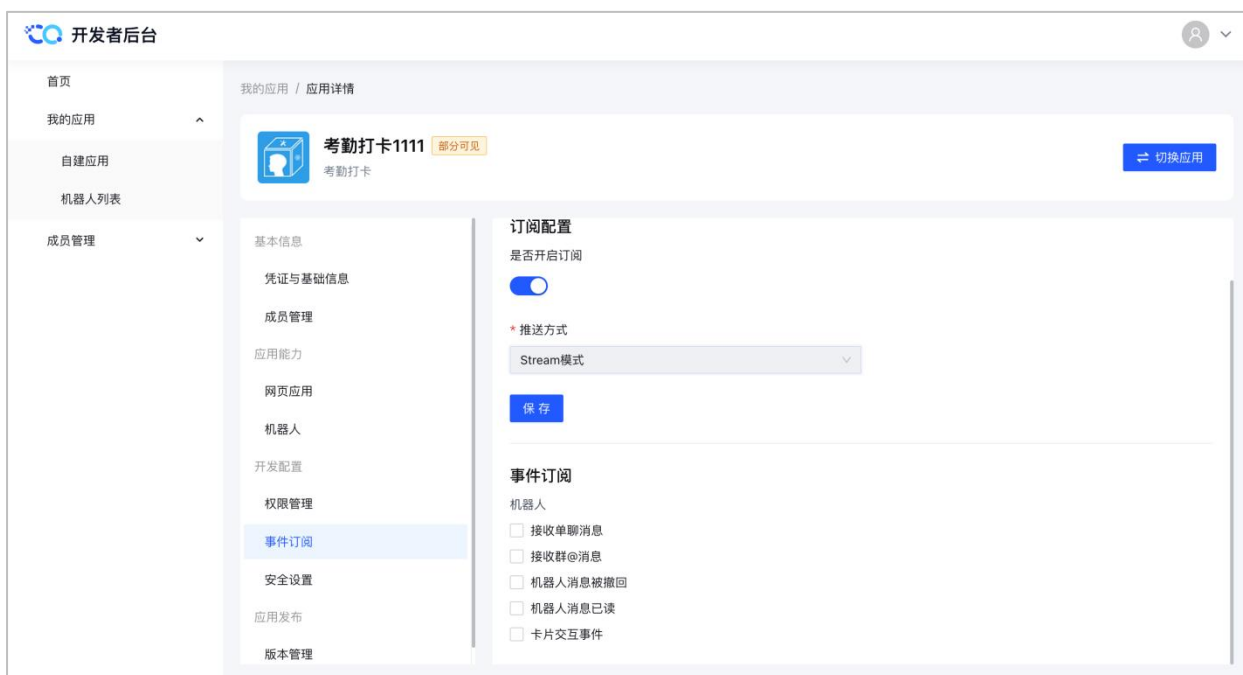
1、用于管控自建应用使用的权限范围，包含基础权限和高级权限。

- 基础权限：默认开通的能力。
- 高级权限：获取日历日程编辑权限，用于日历日程编辑。



#### 4.2.5.6 事件订阅

开启或关闭事件订阅功能。推送方式支持 Stream 模式和 Https 模式。



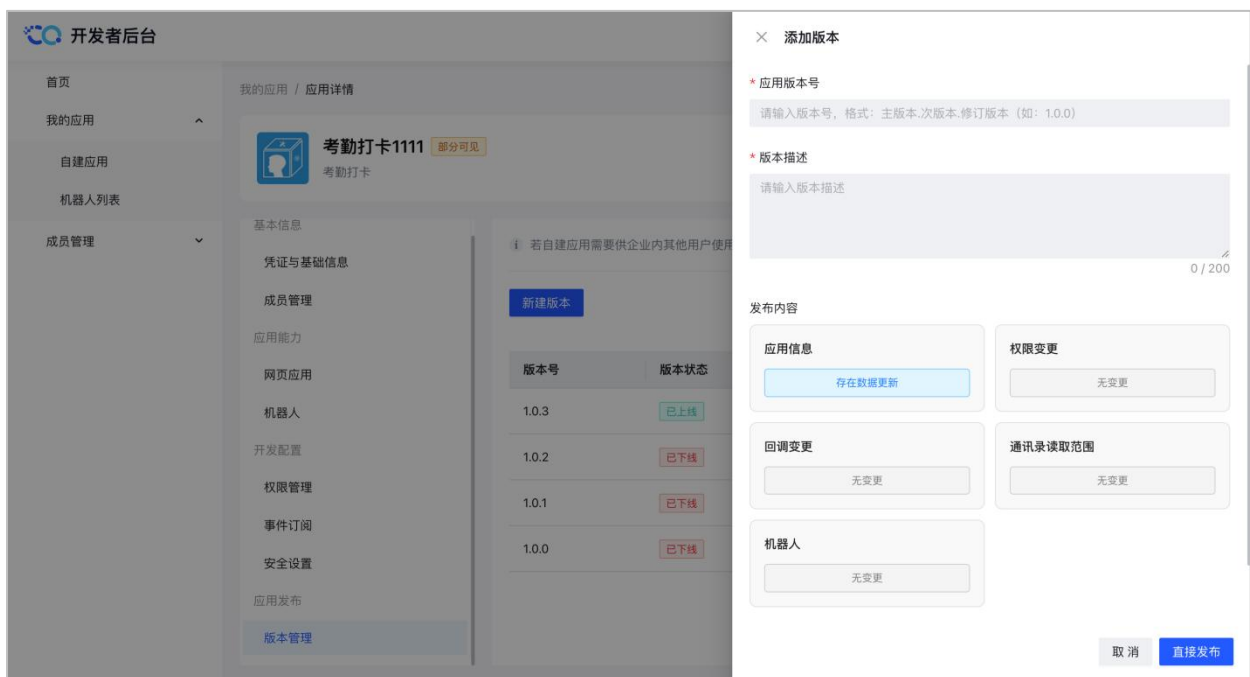
#### 4.2.5.7 安全设置

- 1、用于配置开发接口相关，即时生效。
- 2、免登授权：当前适用于网页应用登录授权。



#### 4.2.5.8 版本管理

对应用配置的版本进行管理。包括应用版本号、版本状态、发布人和发布时间等。



## 4.2.6 商店应用

该模块暂未上线。

## 4.2.7 SDK 应用

该模块暂未上线。

## 4.3 机器人列表

用于管理单位内所有的机器人，包含应用机器人、webhook 机器人两种。

开发者后台

[首页](#)
[我的应用](#)
[自建应用](#)
[机器人列表](#)
[成员管理](#)

[开发者管理](#)
[管理员管理](#)

我的应用 / 机器人列表

应用机器人

webhook机器人

[查询](#)
[重置](#)

| 机器人名称        | 所在群组数量               | 归属应用       | 应用ID | 状态  | 操作                                                         |
|--------------|----------------------|------------|------|-----|------------------------------------------------------------|
| 测试应用ABC      | 商家康十、测试账号3、吕晓亮、13700 | 测试应用ABC    | 2209 | 已启用 | <a href="#">停用</a> <a href="#">详情</a> <a href="#">前往管理</a> |
| 测试机器         | 0                    | 测试1117     | 2236 | 已启用 | <a href="#">停用</a> <a href="#">详情</a> <a href="#">前往管理</a> |
| 1105后端测试01   | 0                    | 1105后端测试01 | 2158 | 已停用 | <a href="#">启用</a> <a href="#">详情</a> <a href="#">前往管理</a> |
| 1103后端开发测试01 | 0                    | 考勤打卡       | 2121 | 已停用 | <a href="#">启用</a> <a href="#">详情</a> <a href="#">前往管理</a> |

共 4 条 < 1 > 10 条/页

开发者后台

[首页](#)
[我的应用](#)
[自建应用](#)
[机器人列表](#)
[成员管理](#)

[开发者管理](#)
[管理员管理](#)

我的应用 / 机器人列表

应用机器人

webhook机器人

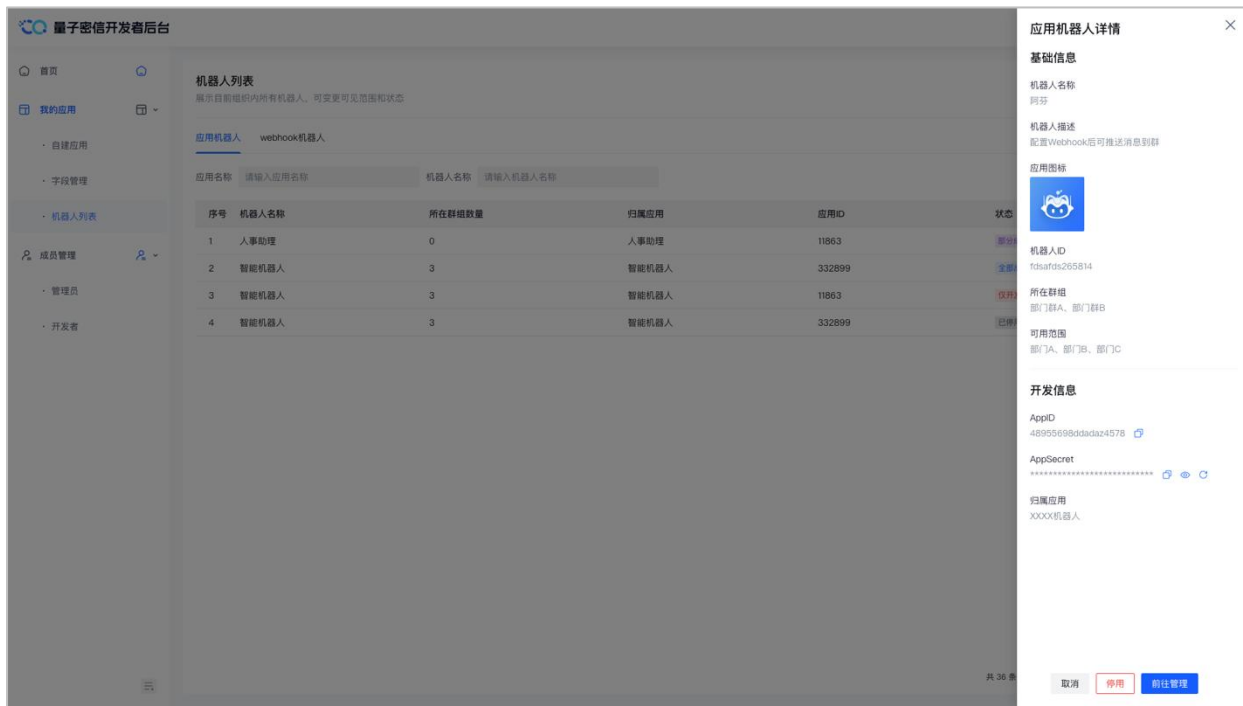
[查询](#)
[重置](#)

| 机器人名称        | 所在群组数量               | 归属应用       | 应用ID | 状态  | 操作                                                         |
|--------------|----------------------|------------|------|-----|------------------------------------------------------------|
| 测试应用ABC      | 商家康十、测试账号3、吕晓亮、13700 | 测试应用ABC    | 2209 | 已启用 | <a href="#">停用</a> <a href="#">详情</a> <a href="#">前往管理</a> |
| 测试机器         | 0                    | 测试1117     | 2236 | 已启用 | <a href="#">停用</a> <a href="#">详情</a> <a href="#">前往管理</a> |
| 1105后端测试01   | 0                    | 1105后端测试01 | 2158 | 已停用 | <a href="#">启用</a> <a href="#">详情</a> <a href="#">前往管理</a> |
| 1103后端开发测试01 | 0                    | 考勤打卡       | 2121 | 已停用 | <a href="#">启用</a> <a href="#">详情</a> <a href="#">前往管理</a> |

共 4 条 < 1 > 10 条/页

### 4.3.1 应用机器人详情

展示应用机器人的基础属性和 appid、appsecret 信息。点击“前往管理”可以跳转到对应机器人的自建应用详情中。



**应用机器人详情**

**基本信息**

机器人名称  
阿芬

机器人描述  
配置Webhook后可推送消息到群

**应用图标**

机器人ID  
fdasafds265814

所在群组  
部门群A、部门群B

可用范围  
部门A、部门B、部门C

**开发信息**

AppID  
489595698ddadaz4578

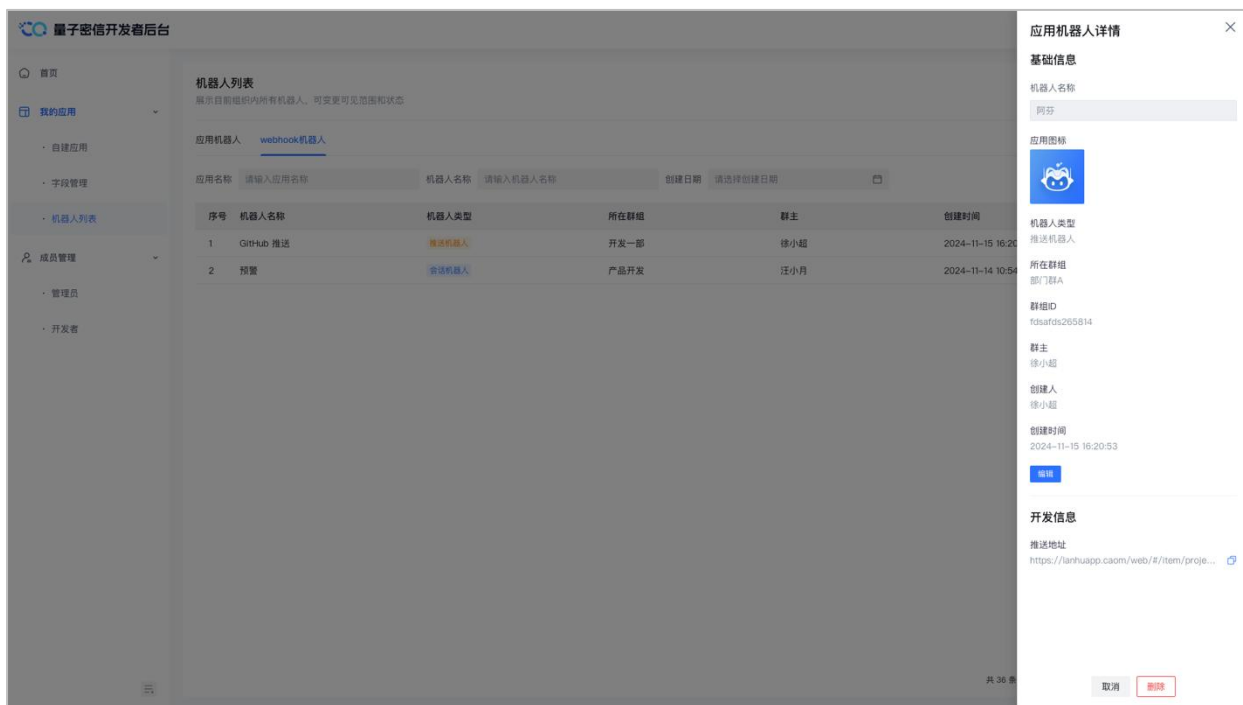
AppSecret  
\*\*\*\*\*

归属应用  
XXXX机器人

取消 停用 前往管理

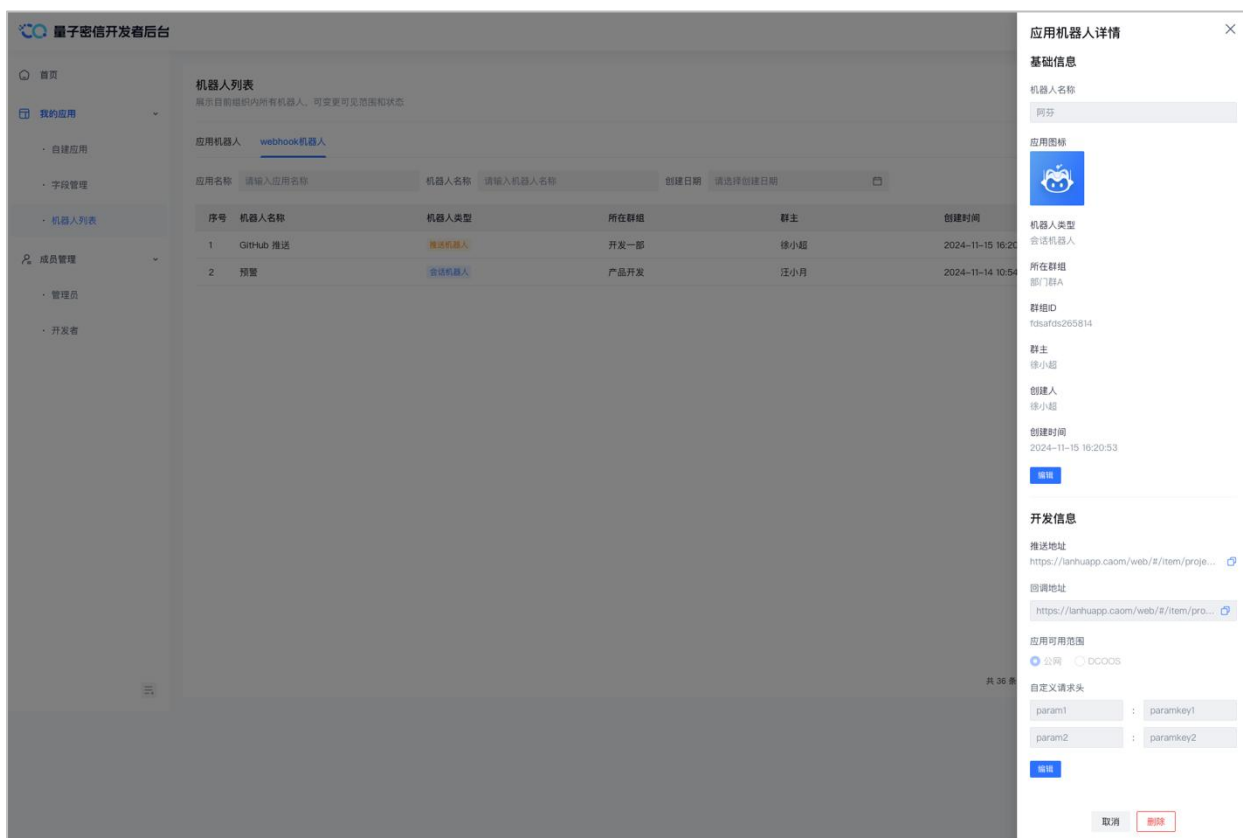
### 4.3.2webhook 推送机器人详情

展示推送机器人的详细信息，包含推送地址和所在群聊的名称。



### 4.3.3webhook 会话机器人详情

展示会话机器人的详细信息，包含推送地址、回调地址等信息。

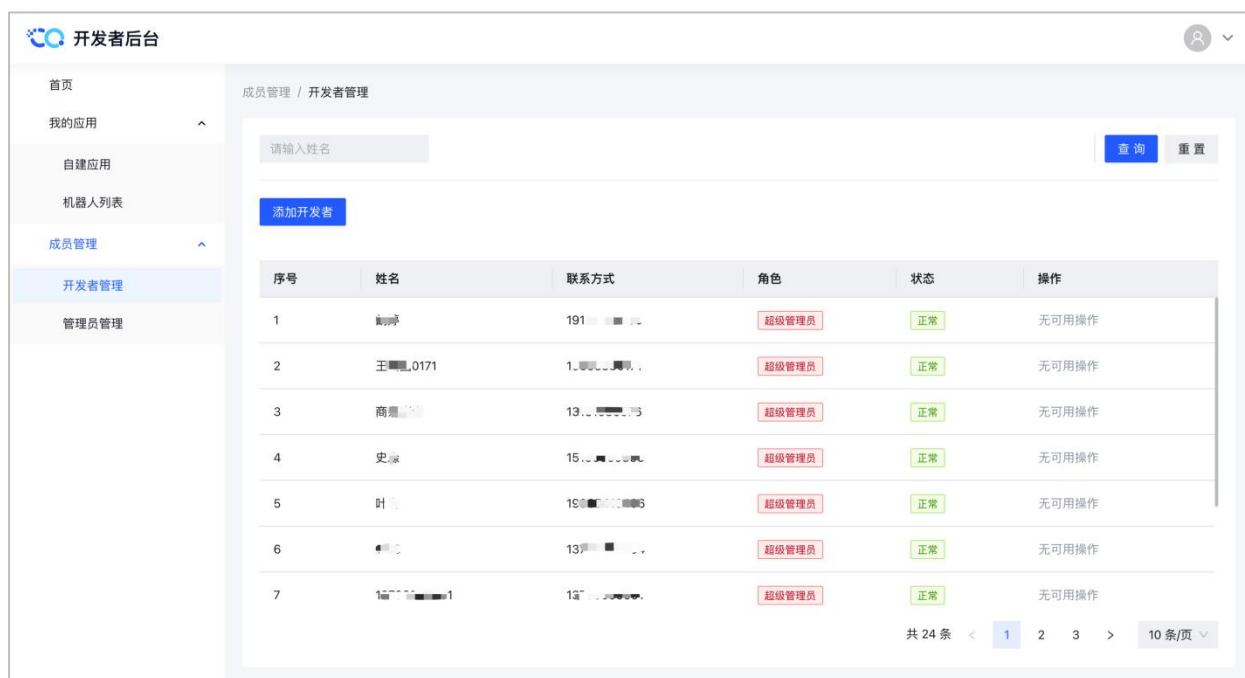


## 4.4 开发者管理

成员管理包括开发者管理和管理员管理。

### 4.4.1 开发者列表

用于管理该单位的开发人员，可以查看人员姓名、联系方式、角色和账号启用状态等。



开发者后台

成员管理 / 开发者管理

请输入姓名 查询 重置

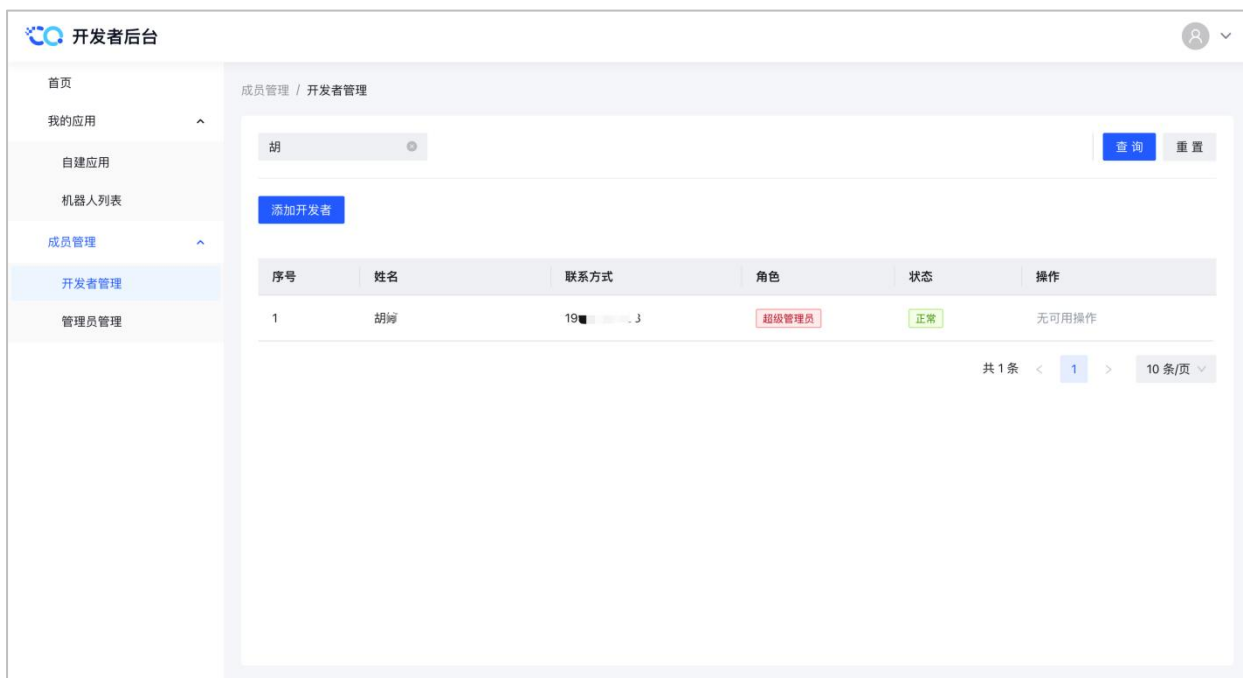
添加开发者

| 序号 | 姓名       | 联系方式          | 角色    | 状态 | 操作    |
|----|----------|---------------|-------|----|-------|
| 1  | 胡峰       | 191-1111-1111 | 超级管理员 | 正常 | 无可用操作 |
| 2  | 王峰峰_0171 | 139-1111-1111 | 超级管理员 | 正常 | 无可用操作 |
| 3  | 商晨       | 139-1111-1111 | 超级管理员 | 正常 | 无可用操作 |
| 4  | 史源       | 151-1111-1111 | 超级管理员 | 正常 | 无可用操作 |
| 5  | 叶        | 191-1111-1111 | 超级管理员 | 正常 | 无可用操作 |
| 6  | 叶        | 139-1111-1111 | 超级管理员 | 正常 | 无可用操作 |
| 7  | 叶        | 139-1111-1111 | 超级管理员 | 正常 | 无可用操作 |

共 24 条 < 1 2 3 > 10 条/页

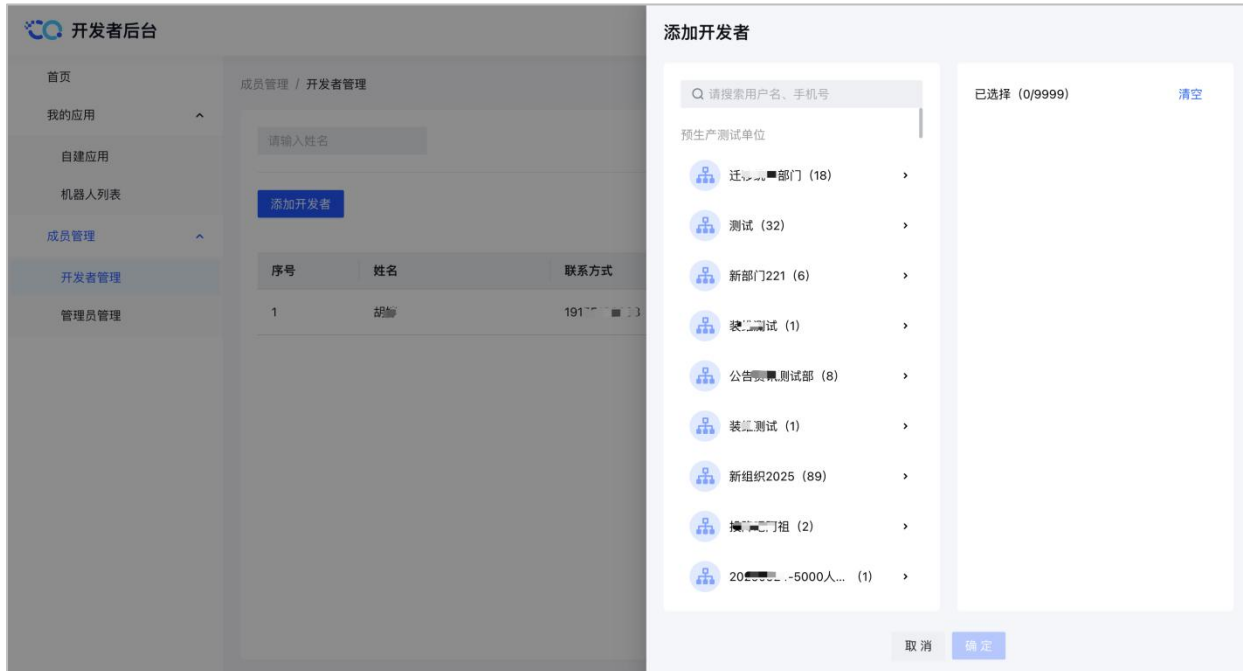
### 4.4.2 查询开发者

在搜索框中输入人员姓名，再点击右侧的【查询】按钮，即可查询出人员。



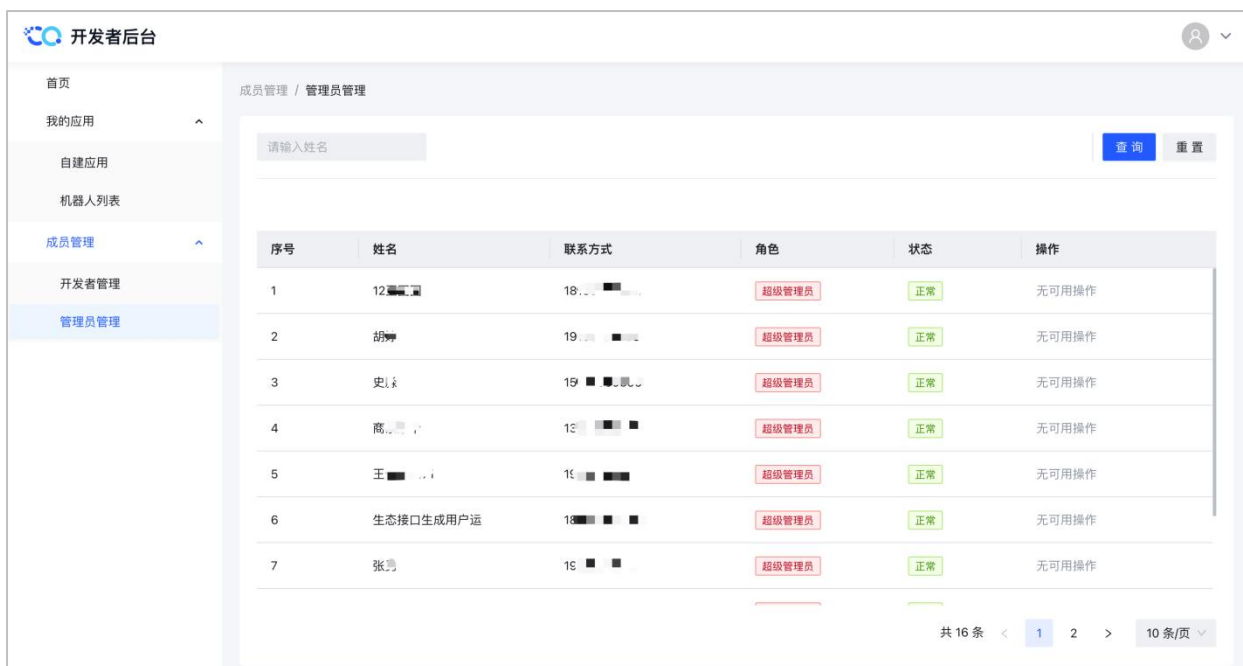
#### 4.4.3 添加开发者

从单位组织架构中选择成员，将其添加为开发者。



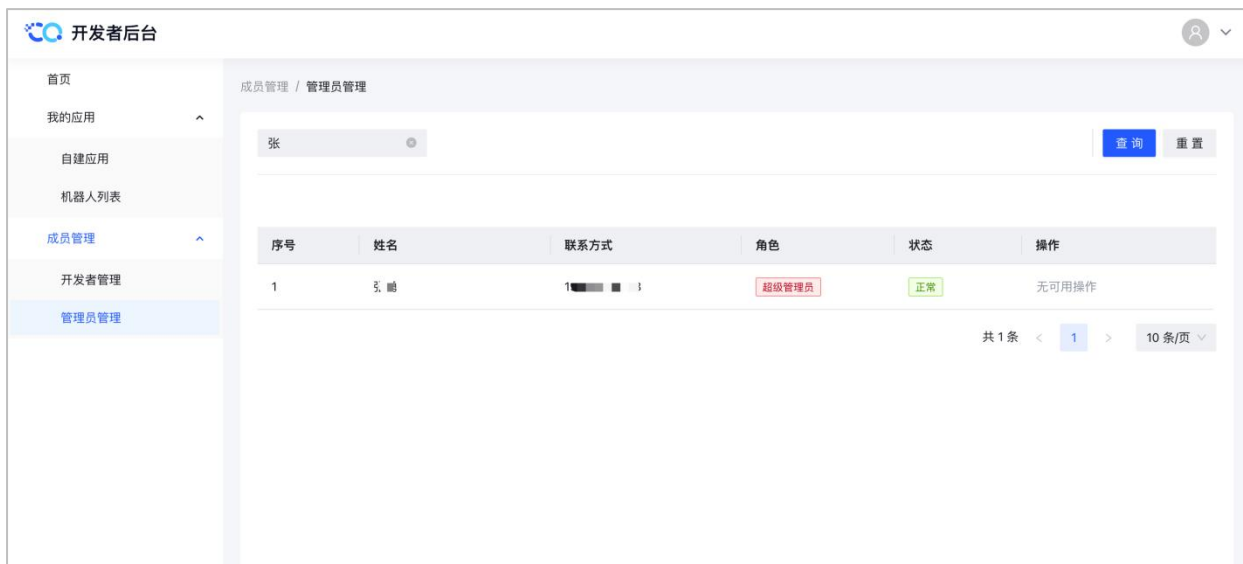
#### 4.5 管理员列表

用于配置具有开发者后台管理权限的账号。



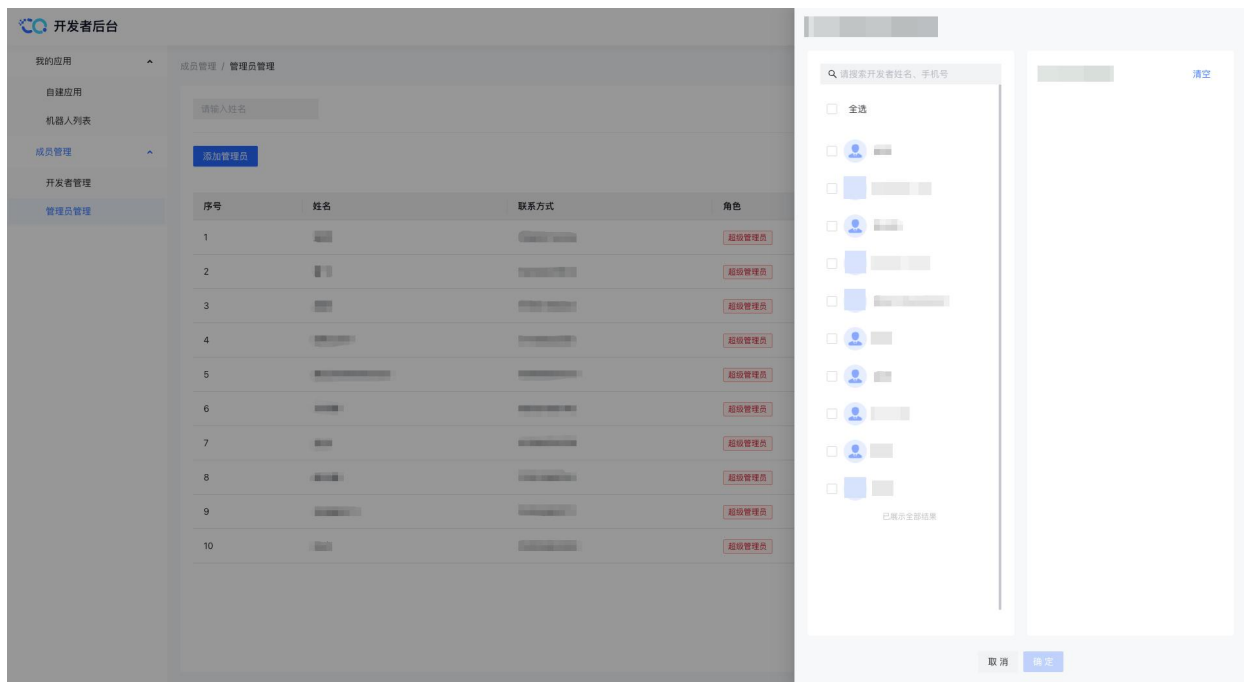
#### 4.5.1 查询管理员

在搜索框中输入人员姓名，再点击右侧的【查询】按钮，即可查询出人员。



#### 4.5.2 添加管理员

- 1、单位超级管理员默认同步到开发者后台作为管理员。
- 2、管理员可以从开发者列表选择添加。



## 5. 开发内部应用

### 5.1 开发流程

#### 5.1.1 开发步骤

##### 5.1.1.1 获得开发者权限

##### 登录开发者后台

默认仅单位超级管理员可登录，其他成员登录请查看【开发者添加】让单位管理员添加 [https://dev-mixin.zdxyz.com/ctq\\_login/](https://dev-mixin.zdxyz.com/ctq_login/)

- 打开开发者后台登录页



- 输入账号与密码并登录，进入开发者后台



- （可选）若账号关联多个组织，系统会进入“组织单位选择”页面，选择要访问的组织后进入后台首页



## 开发者添加

1. 单位管理员或开发者管理员登录后，进入 开发者管理 页面

开发者后台

成员管理 / 开发者管理

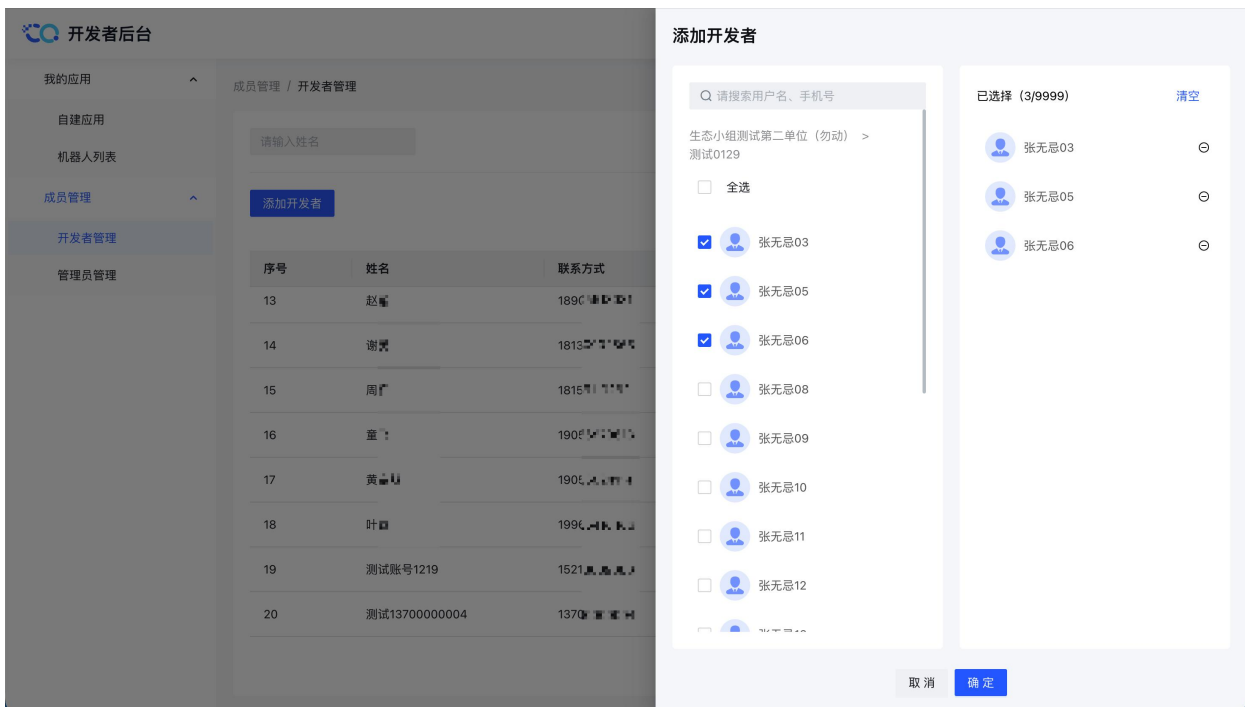
请输入姓名 查询 重置

添加开发者

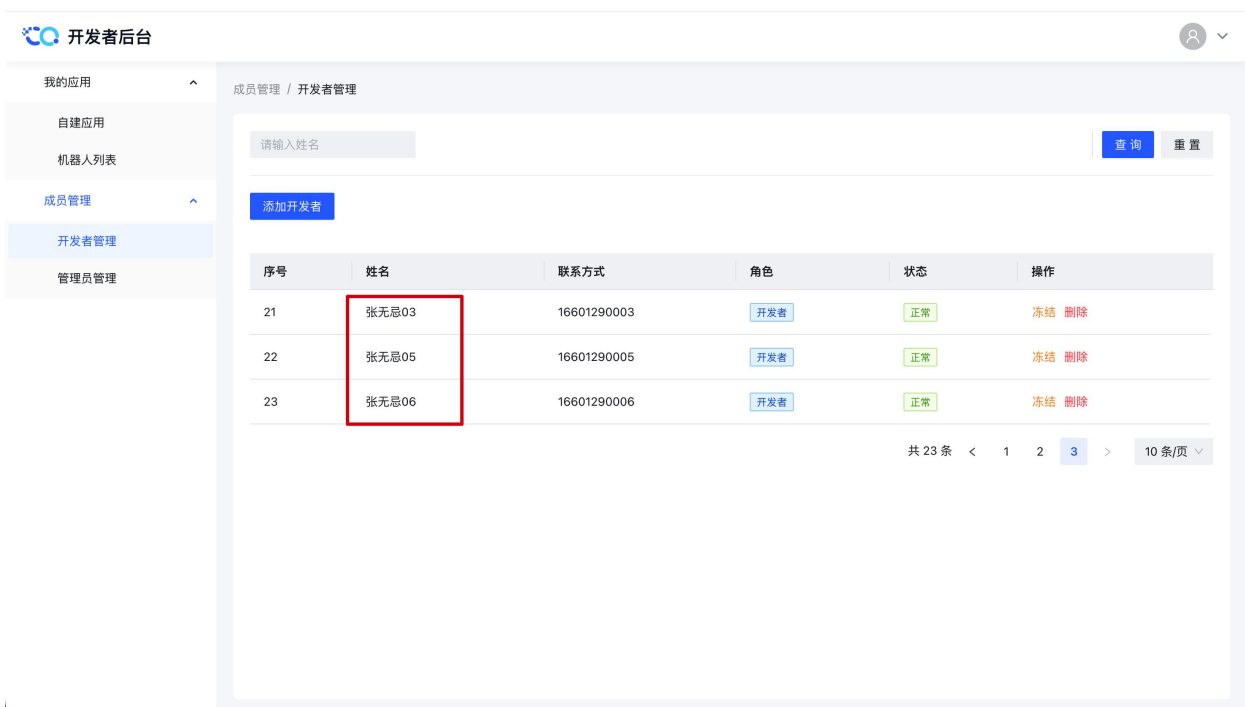
| 序号 | 姓名            | 联系方式 | 角色    | 状态 | 操作    |
|----|---------------|------|-------|----|-------|
| 13 | 赵             | 189  | 超级管理员 | 正常 | 无可用操作 |
| 14 | 谢             | 181  | 超级管理员 | 正常 | 无可用操作 |
| 15 | 周             | 181  | 超级管理员 | 正常 | 无可用操作 |
| 16 | 董             | 190  | 超级管理员 | 正常 | 无可用操作 |
| 17 | 黄             | 190  | 超级管理员 | 正常 | 无可用操作 |
| 18 | 叶             | 199  | 超级管理员 | 正常 | 无可用操作 |
| 19 | 测试账号1219      | 152  | 开发者   | 正常 | 冻结 删除 |
| 20 | 测试13700000004 | 137  | 开发者   | 正常 | 冻结 删除 |

共 20 条 < 1 2 > 10 条/页

2. 点击“添加开发者”，并选择当前单位通讯录中的成员

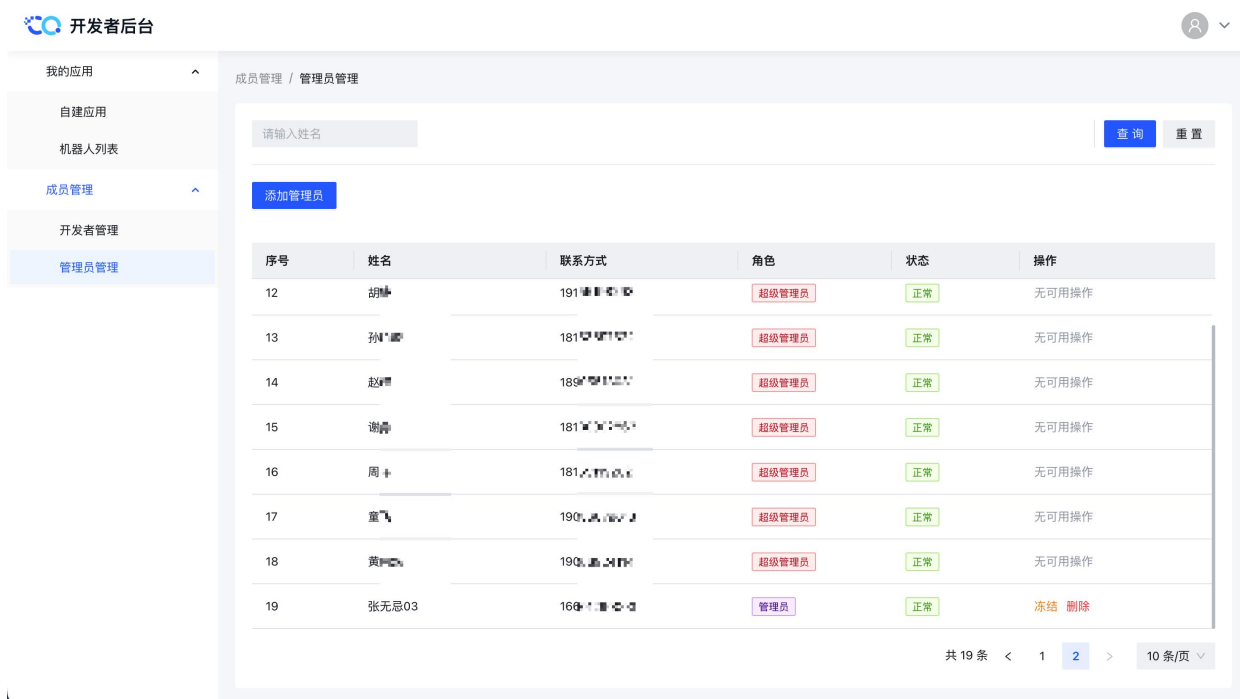


3. 选择完成后确认，成功添加到列表。对应账号即可登录开发后台

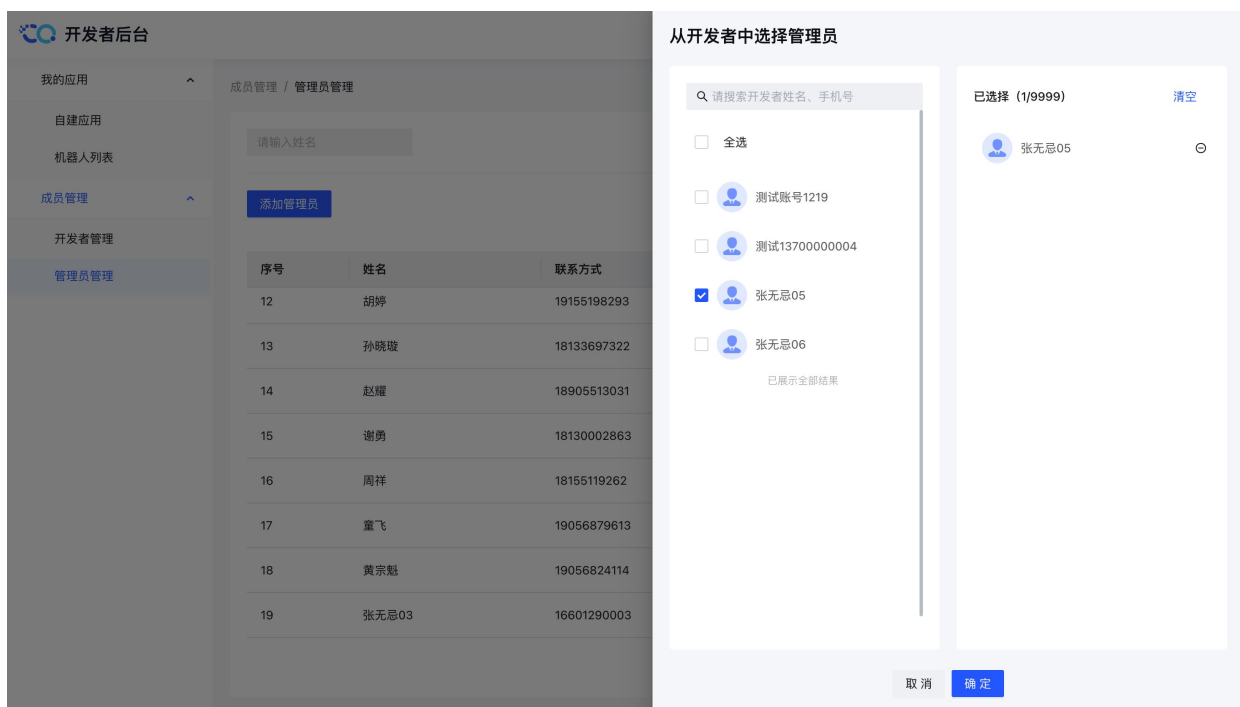


添加开发者管理员

1. 进入管理员列表（单位超级管理员默认已具备管理权限且不可移除）



2. 点击“添加管理员”，从开发者列表选择人员添加到管理员

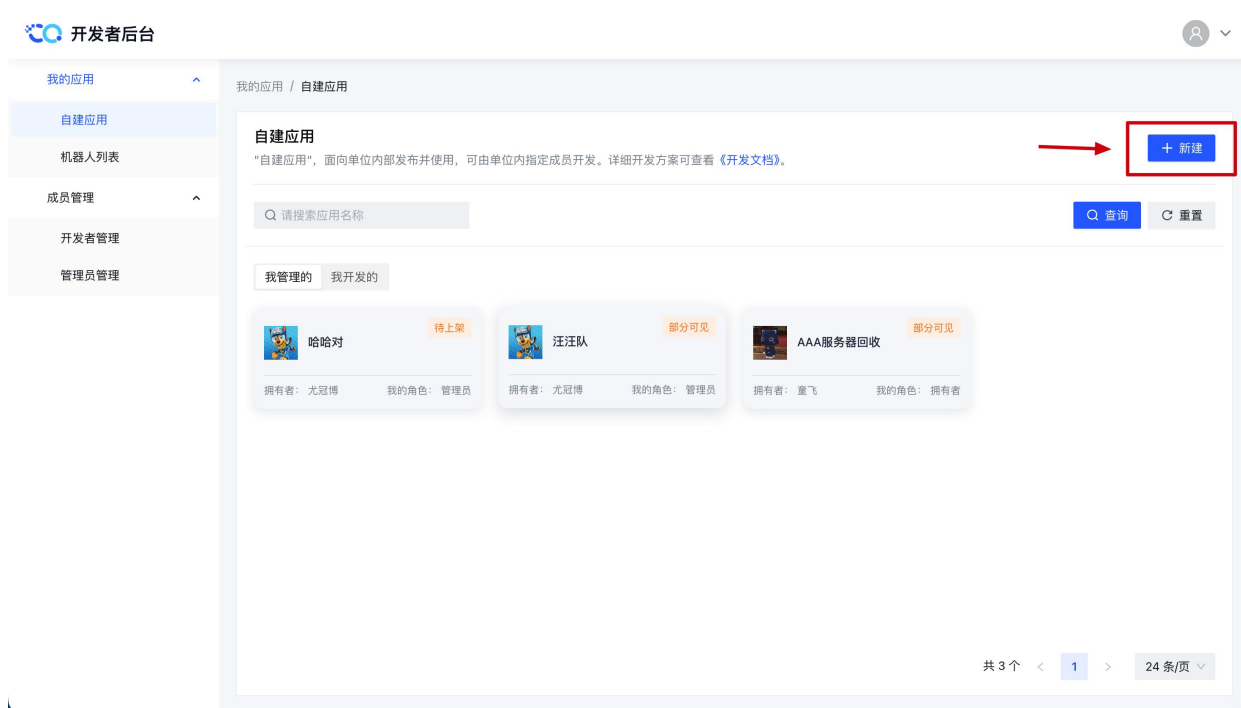


## 结果确认

完成登录后，左侧菜单展示“我的应用”等功能入口；若无相关菜单，通常表示权限未开通或当前组织无应用权限。

### 5.1.1.2 创建应用

#### 1. 进入“自建应用”页面，点击“新建应用”

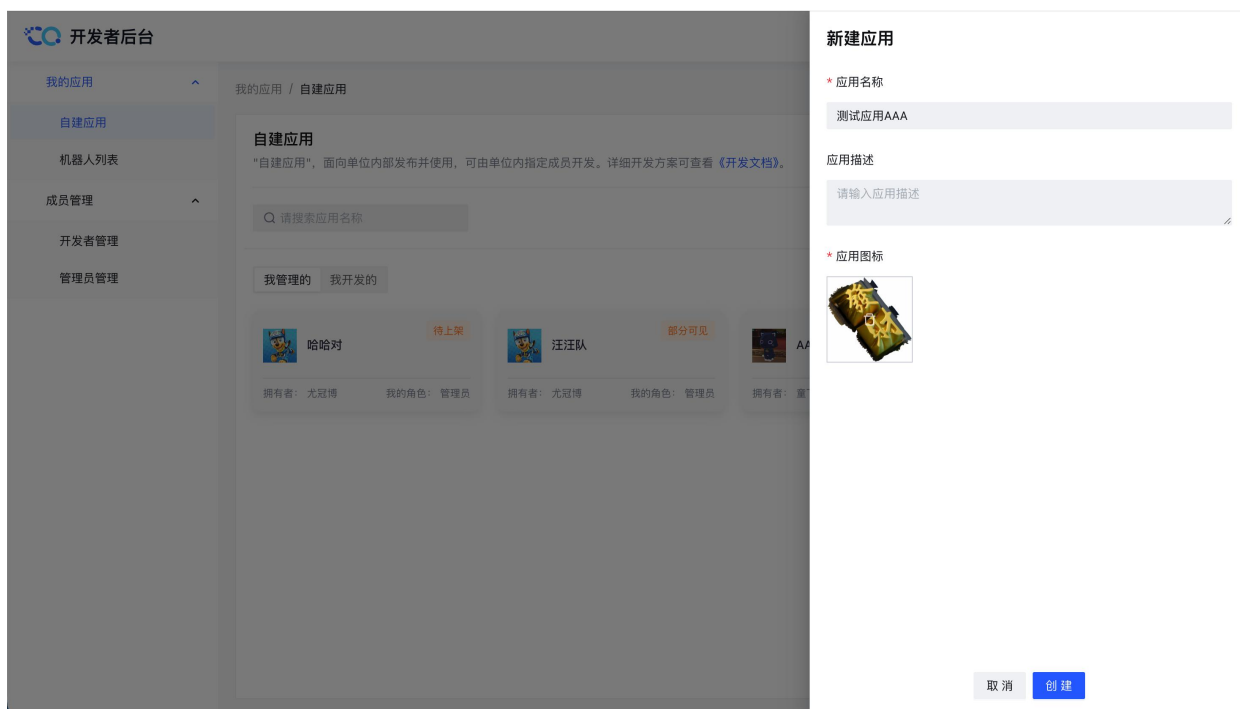


#### 2. 在弹窗中填写：

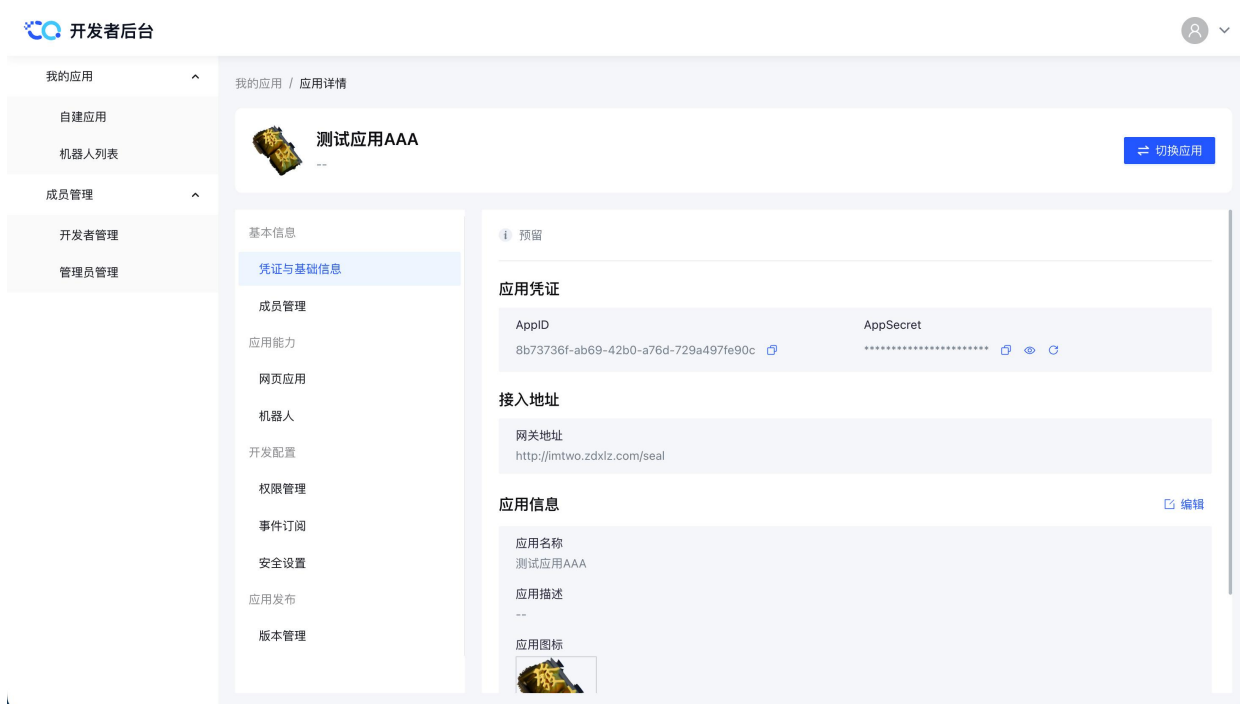
应用名称：必填项，支持输入 2-20 个字符的中英文数字加常用符号，不限制重名

应用图标：必填项，上传应用图标，要求 PNG 格式、120\*120px 以上、1:1、圆角 18、2MB 以内的图标

应用描述：非必填，简要描述应用提供的产品或服务，支持输入最多 200 个字符的中英文数字加常用符号



3. 点击“创建”完成应用创建，自动进入应用详情

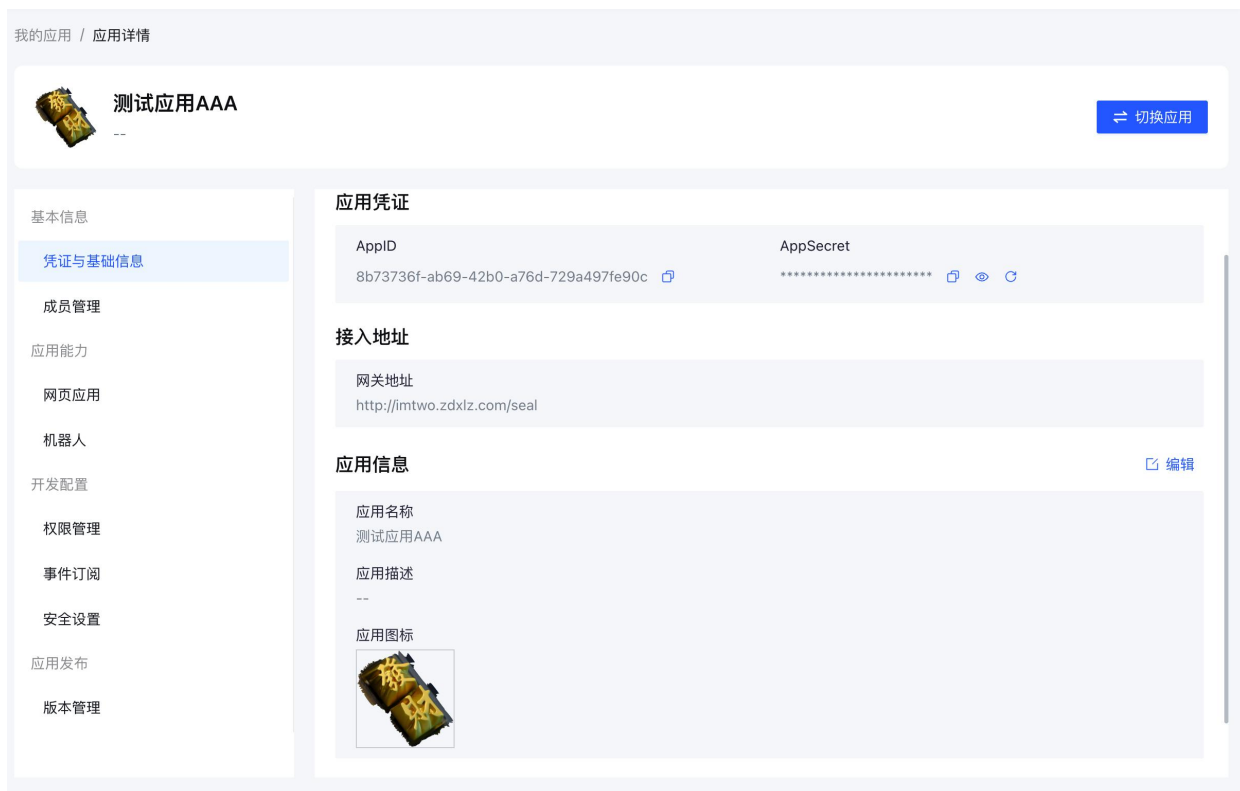


4. 新建应用会出现在应用列表中，初始状态为“待上架”，点击应用卡片进入应用详情页继续配置

### 5.1.1.3 配置应用引导

入口路径：我的应用 → 自建应用 → 进入应用详情页

#### 1. 凭证与基础信息



#### 【应用凭证】

**AppId:** 应用唯一标识，系统自动生成，应用使用 AppId&AppSecret 通过开发者后台接口换取 AppToken。

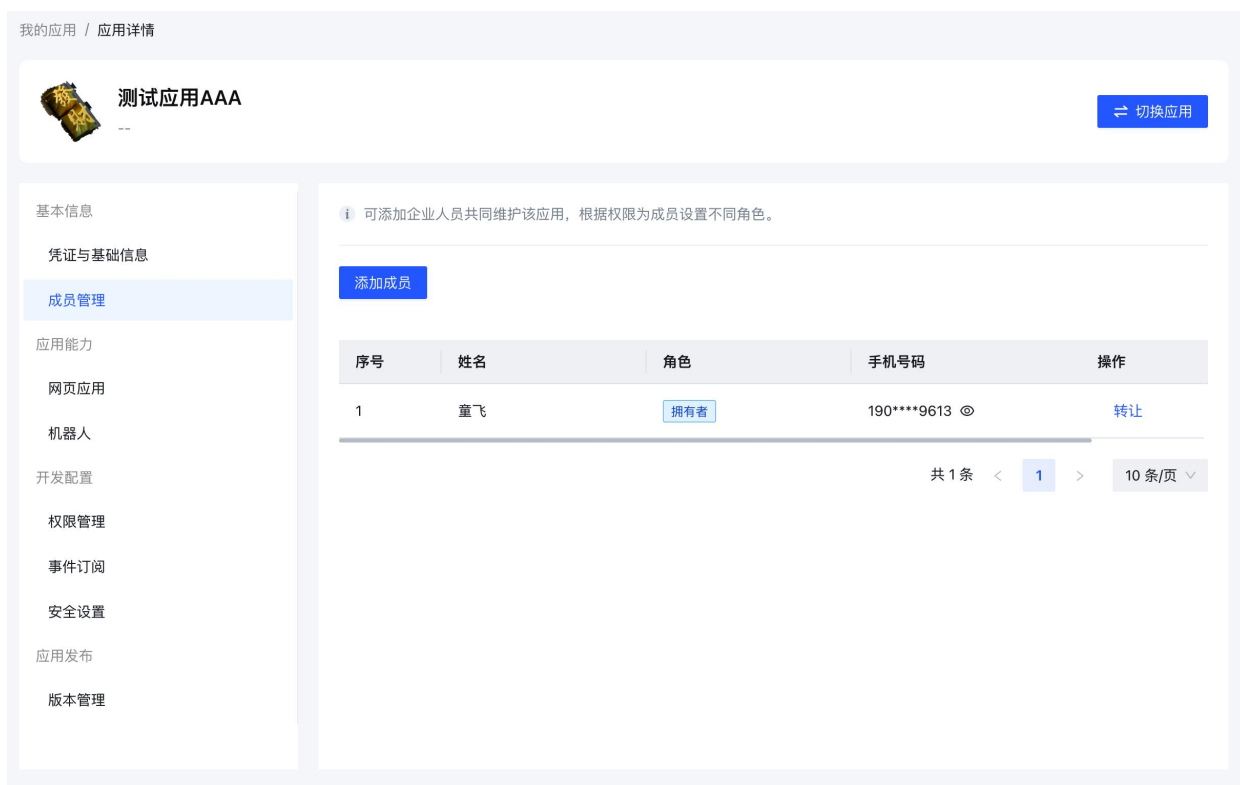
**AppSecret:** 应用密钥，系统自动生成，默认脱敏展示，支持复制、查看和重置，开发者需要妥善保管，应用使用 AppId&AppSecret 通过开发者平台接口换取 AppToken。

#### 【应用信息】

展示应用基础信息，可编辑应用名称/描述/图标

可操作应用停用或删除应用（删除需先停用）

#### 2. 成员管理



管理当前应用的开发人员

- 可添加/删除应用成员
- 应用创建人默认为拥有者，可转让
- 角色说明：
  - ◆ 拥有者&后台管理员：该应用的拥有人，拥有应用最高权限
  - ◆ 管理员：拥有应用管理权限，无法删除应用
  - ◆ 开发者：应用的开发者，无法成员管理、无法停用应用+删除应用、无法发布版本

### 3. 网页应用配置

我的应用 / 应用详情


**测试应用AAA**
切换应用

基本信息  
 凭证与基础信息  
 成员管理  
 应用能力  
**网页应用**  
 机器人  
 开发配置  
 权限管理  
 事件订阅  
 安全设置  
 应用发布  
 版本管理

*i* 显示在 客户端-工作台 的网页应用。

网页应用是否开启

☒

入口配置 + 新增

| 平台      | 跳转链接                                 | 最小app版本                             | 是否免登                     | 外部打开                     | 操作                 |
|---------|--------------------------------------|-------------------------------------|--------------------------|--------------------------|--------------------|
| iOS     | <input type="text" value="请输入链接地址"/> | <input type="text" value="请输入版本号"/> | <input type="checkbox"/> | <input type="checkbox"/> | <a href="#">删除</a> |
| Android | <input type="text" value="请输入链接地址"/> | <input type="text" value="请输入版本号"/> | <input type="checkbox"/> | <input type="checkbox"/> | <a href="#">删除</a> |
| Windows | <input type="text" value="请输入链接地址"/> | <input type="text" value="请输入版本号"/> | <input type="checkbox"/> | <input type="checkbox"/> | <a href="#">删除</a> |

管理后台地址

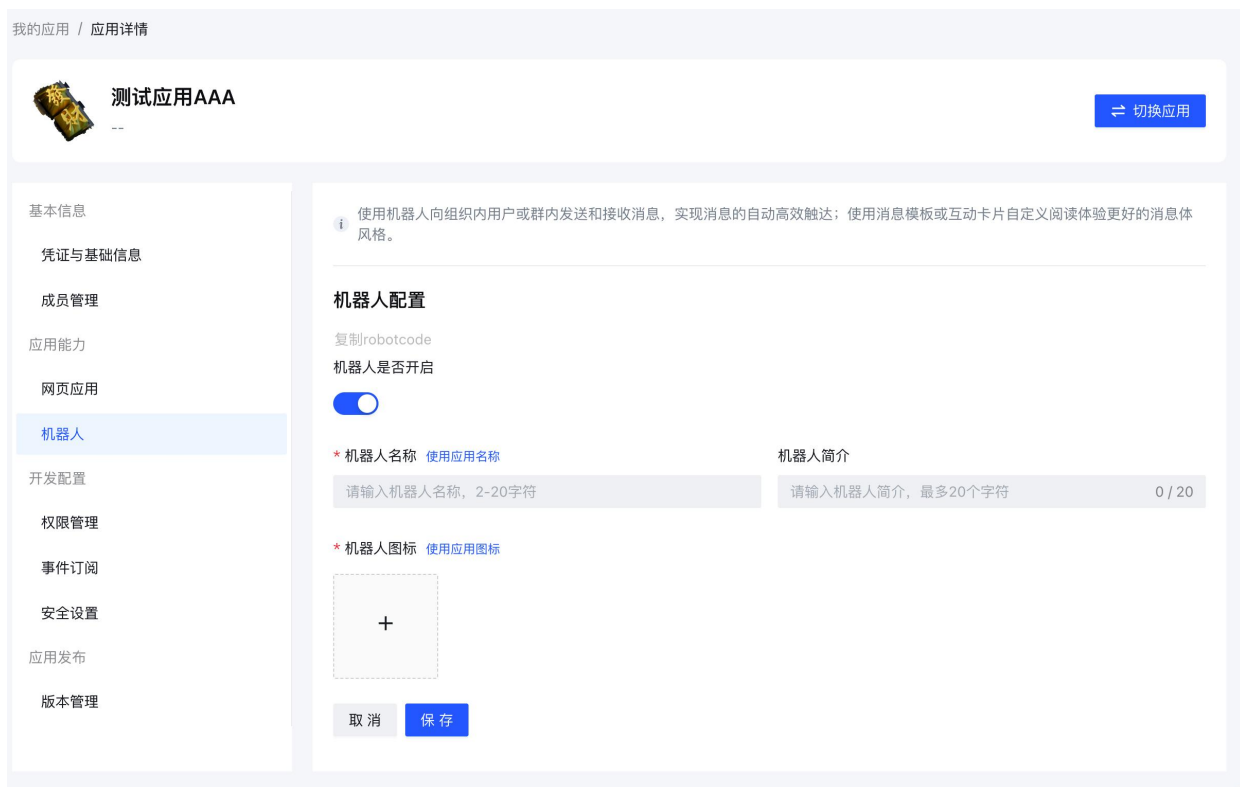
取消 保存

开启网页应用后需配置入口与（可选）管理后台地址，并可设置：

- 平台：Windows/Android/iOS/HarmonyOS/多种信创与 MacOS 等
- 跳转链接：必填，http 或 https 开头
- 最小 App 版本：可选，用于旧版本兼容治理（量子密信版本，非应用版本）
- 免登：启用免登重定向
- 外部打开：控制是否走系统浏览器，仅对桌面端系统生效（Windows、MacOS、信创）
- 管理后台地址：可选，用于管理应用配置

服务端授权、客户端免登请查看【网页应用开发指南】模块。

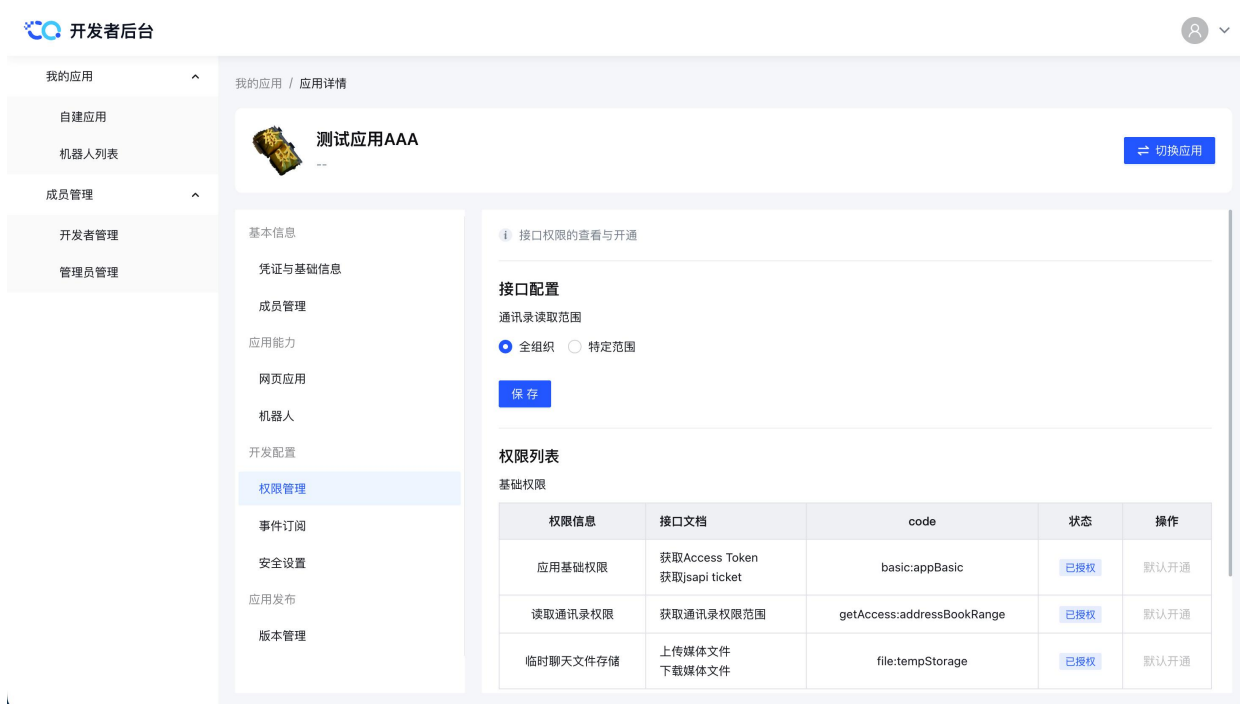
#### 4. 机器人配置



开启机器人后需配置：

- 机器人编码（robotcode，API 唯一识别）
- 名称、描述、图标等基础信息

## 5. 权限管理



用于配置自建应用可使用的权限范围（基础权限/高级权限等）。

## 6. 事件订阅

我的应用 / 应用详情

 **测试应用AAA** 切换应用

基本信息

凭证与基础信息

成员管理

应用能力

网页应用

机器人

开发配置

权限管理

**事件订阅**

安全设置

应用发布

版本管理

**订阅配置**

是否开启订阅

☒

\* 推送方式

Stream模式

保存

**事件订阅**

机器人

☐ 接收群@消息

☐ 卡片交互事件

☐ 接收单聊消息

☐ 机器人消息已读

☐ 机器人消息被撤回

推送方式：

- Stream：暂不支持，选择后可直接勾选需要订阅的事件
- HTTPS：配置回调地址并勾选回调事件。支持 DC00S 自定义请求头

## 7. 安全设置

我的应用 / 应用详情


**测试应用AAA**
切换应用

基本信息

凭证与基础信息

成员管理

应用能力

网页应用

机器人

开发配置

权限管理

事件订阅

**安全设置**

应用发布

版本管理

### 免登授权

授权类型:

☒ OAuth2.0/OIDC ☐ SSO

**\* 重定向URL**

请输入重定向URL

添加重定向URL作为免登授权码跳转地址，多个地址用"|"分隔。

保存

0 / 1000

### 接口安全

服务器出口IP:

请输入服务器出口IP

调用服务端API的服务器IP列表，多个IP请以","隔开

0 / 1000

- 免登授权：配置授权类型与重定向白名单，可添加多个
- 接口安全：配置服务器出口 IP 白名单，不填写则不限制

#### 5.1.1.4 应用使用与发布

入口路径：我的应用 → 自建应用

##### 1. 使用工作台应用

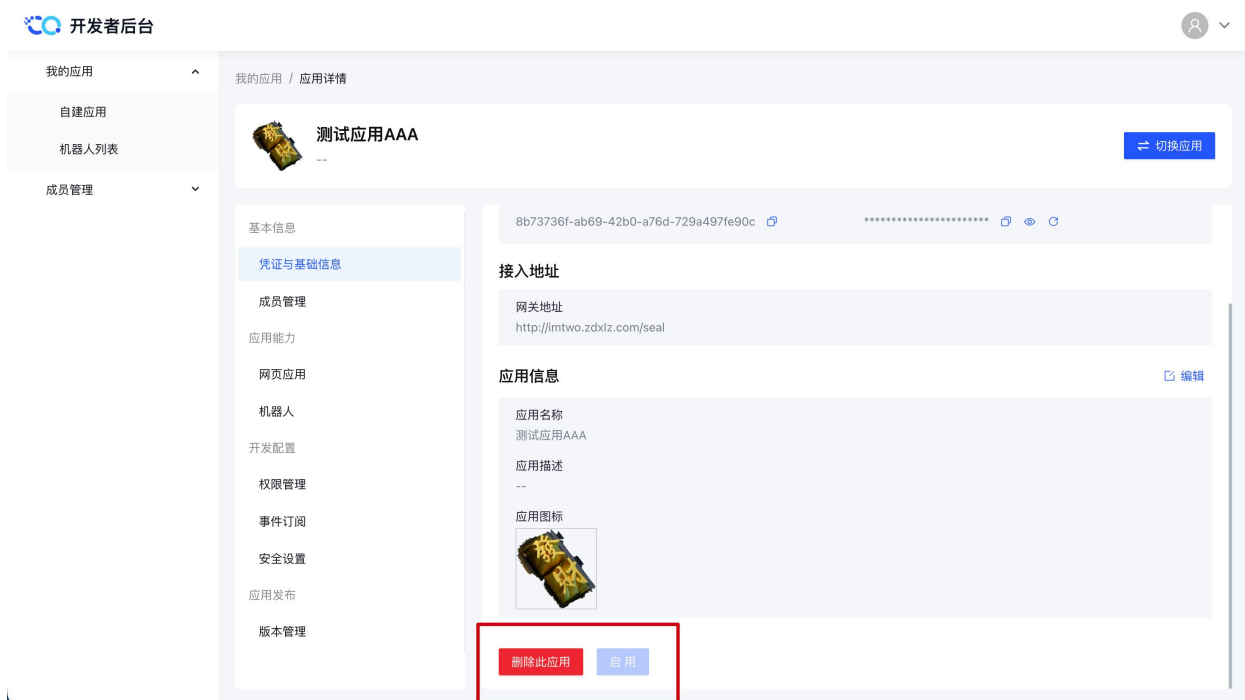
1. 自建应用启用“网页应用”能力并发布后，应用使用范围的用户查看工作台
2. 在默认工作台最下方的“未分组”下会出现该应用
3. 点击跳转到对应平台的链接地址，（若包含免登能力，链接填写时注意加上 `redirected_uri` 参数）

##### 2. 使用机器人



1. 自建应用启用“机器人”能力并发布后，使用范围的用户可在内部群聊添加机器人
2. 群聊添加应用机器人后，调用应用机器人发送消息接口，给指定群聊发送消息
3. 群内@该机器人，可将消息发送到回调地址（事件订阅 中录入回调地址）

### 3. 停用或删除应用

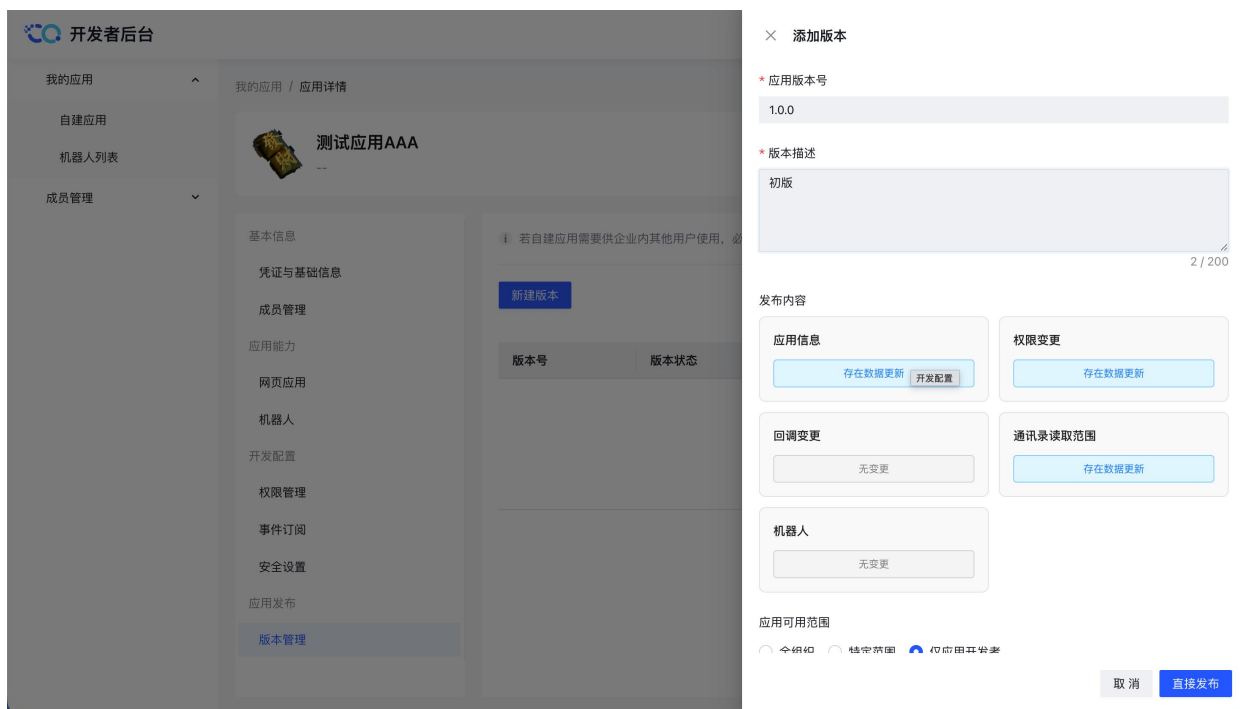


■ 停用应用：停用后应用状态更新，且不在管理后台显示

■ 删除应用：必须先停用，再执行删除

#### 4. 发布应用





影响客户端展示与可用性的配置变更，通常在“发布”后才生效。版本管理用于记录版本号、版本状态、发布人和发布时间，并支持查看哪些配置模块发生变更。

- ◆ 创建应用版本，填写版本号与版本描述
  - 版本号为三段式（如 1.0.0），新增版本需大于已发布版本
- ◆ 检查“发布内容”，确认哪些模块发生变更（基础信息、网页入口、机器人配置、读取范围、权限、事件订阅等）
- ◆ 设置“应用可用范围”：
  - 全部成员：单位内所有成员
  - 部分成员：选择通讯录范围
  - 仅应用开发者：应用成员管理内的成员可见，用于调试
- ◆ 若发布到“全部成员/部分成员”，需管理后台对应角色审核通过后，版本才正式发布

## 推荐发布流程

- 测试应用：发布到“仅应用开发者”，在客户端仅应用的开发人员可见（不含后台管理员）
- 灰度发布：先发布到“部分成员”验证，再逐步扩大范围
- 分部门上线：按业务推广节奏分批开放
- 专项应用：仅对某些部门开放，避免影响其他成员

## 5.1.2 应用部署与测试

### 一、部署对象

- 网页应用前端页面（H5）
- 网页应用服务端（用于授权回调、token 管理、接口调用）
- 事件订阅回调服务（HTTPS 回调接收端）
- 机器人回调服务（如有）

### 二、部署建议

#### 1. 使用 HTTPS

建议所有入口与回调地址使用 HTTPS，确保授权与回调链路安全。

#### 2. 高可用与扩展

- 授权回调与事件回调建议部署为无状态服务，支持横向扩容
- 建议配置健康检查与自动伸缩策略，避免峰值失败

#### 3. 安全配置联动

部署完成后需回到开发者后台完成以下配置联动：

- 网页应用入口 URL（按端配置）
- 免登授权重定向 URL 白名单（如启用免登）
- 事件订阅回调地址、签名 token、加密 key（HTTPS 模式）
- 服务端出口 IP 白名单（如启用限制）

### 三、测试范围建议

- 网页应用入口：各端入口是否可打开、外部打开策略是否符合预期
- 免登授权：首次进入是否弹授权、回调是否成功、用户信息是否可获取
- 权限：调用接口是否存在权限不足、scope 是否满足业务
- 事件订阅：回调是否可达、是否验签通过、解密后内容是否正确
- 版本：发布内容变更项是否覆盖本次改动点

#### 四、结果确认

- 网页应用可从量子密信客户端入口稳定打开
- 授权回调与事件回调可达且验签通过
- 若后台提供“调试测试”能力，可用于验证 HTTPS 回调连通性

测试通过后再调整可用范围并提交审核发布，避免将不稳定版本直接暴露给全员。

### 5.1.3 应用自检表

#### 一、基础信息自检

- ☐ 应用名称、描述、图标符合规范
- ☐ AppSecret 已按要求妥善保管（仅服务端保存）

#### 二、网页应用自检（如启用）

- ☐ 各端平台入口已配置且 URL 正确
- ☐ 最小 App 版本策略符合兼容性预期
- ☐ 外部打开策略符合安全与体验要求
- ☐ 管理后台地址（如配置）可正常访问

#### 三、授权与安全自检（如启用免登）

- ☐ 已配置授权类型与重定向白名单（可添加多个）
- ☐ redirect\_uri 与授权请求保持一致
- ☐ state 已实现保存与校验（CSRF 防护）

#### 四、事件订阅自检（如启用 HTTPS 回调）

- ☐ 回调地址可达
- ☐ 已配置签名 token 与加密 key
- ☐ 已实现“先验签、后解密、再处理”的服务端逻辑

## 五、版本发布自检

- [ ] 版本号与版本描述填写完整
- [ ] 发布内容变更项与本次发布范围一致
- [ ] 可用范围设置正确（测试/部分/全量）
- [ ] 若涉及全部/部分成员，已按流程提交审核

### 5.1.4 安全运营

#### 一、密钥与凭证管理

- AppSecret 为高敏信息，需分权管理，严禁在前端暴露
- 如发生泄露风险，应及时在后台重置 AppSecret 并完成服务端同步更新

#### 二、授权与重定向治理（免登场景）

- 重定向白名单应遵循最小化原则，仅添加必要域名
- 授权类型变更、白名单变更属于高风险变更，建议走单位内部变更流程并在低峰发

布

#### 三、接口访问控制

- 可配置“服务器出口 IP 白名单”限制调用平台接口的服务器出口 IP
- 建议结合单位网络策略，仅允许生产环境出口访问

#### 四、回调安全（事件订阅 HTTPS）

- 必须启用并正确使用签名 token 与加密 key
- 服务端处理顺序必须为：先验签 → 后解密 → 再处理
- 记录验签失败与解密失败日志，用于风险审计

#### 五、版本与变更治理

- 版本发布前核对“发布内容”变更项，避免误发布
- 权限、事件订阅、授权相关配置变更建议重点评审
- 发现异常可通过版本回退或停用应用止损（按单位内部流程执行）

## 5.2 开发网页应用

### 5.2.1 网页应用开发指南

#### 一、网页应用概览

##### 1. 什么是网页应用

网页应用是指以 H5 页面形态接入量子密信的应用能力。开发者通过在开发者后台为自建应用配置网页入口，使单位成员可以从量子密信客户端工作台进入应用页面并完成业务操作。

网页应用通常承载单位已有业务系统或新开发的 Web 服务；平台负责提供统一入口、账号与安全能力，网页内容与业务数据由开发者自有系统承载与维护。

##### 2. 能力边界

网页应用能力聚焦于“入口与访问”，不托管业务系统本身：

- 平台负责：入口配置、可见范围、免登授权能力、安全校验与相关接口能力
- 开发者负责：页面开发与部署、业务逻辑与数据存储、应用可用性与安全运维

如需消息交互、通知推送、事件驱动等能力，建议结合机器人能力或服务端事件机制实现。

##### 3. 适用场景

网页应用适用于以下场景：

- 单位内部业务系统接入（OA、审批、资产、运维、报表等）
- 信息展示与数据查询类应用
- 管理后台与运营系统

- 需要复杂页面交互的业务功能

## 二、接入架构与授权模型

网页应用接入通常涉及两类“身份”：

- 用户身份（用户授权登录）：识别“当前访问网页应用的是谁”，用于获取用户信息或以用户身份访问受保护资源

- 应用身份（服务端 access\_token）：识别“调用接口的是哪个应用”，用于服务端对服务端接口调用

平台提供两套授权流程（接口细节详见授权接口文档）：

- 客户端授权（授权码模式）：authorize 获取 code → 服务端换取用户授权 access\_token → userinfo 获取用户信息 → （可选）refresh 刷新

- 服务端授权（客户端凭证模式）：client\_credentials 获取应用 access\_token → 携带 token 调用资源接口

选型表：什么时候用哪种授权

| 需求/场景                           | 推荐方式                | 说明                              |
|---------------------------------|---------------------|---------------------------------|
| 网页应用需要识别当前用户是谁                  | 客户端授权（授权码模式）        | 通过 code 换取用户授权 token，再获取用户信息    |
| 网页应用需要获取“用户可访问的数据”（与用户绑定的权限/数据） | 客户端授权（授权码模式）        | 以用户身份获得授权范围内的数据访问能力             |
| 服务端定时任务/系统同步，不区分具体用户            | 服务端授权（客户端凭证模式）      | 以应用身份调用接口，不涉及用户授权               |
| 后端需要调用资源接口（自建应用接口/平台资源接口）       | 服务端授权（客户端凭证模式）      | 获取应用 access_token 后携带 Bearer 调用 |
| 同时需要“识别用户 + 后端系统调用”             | 两种方式组合              | 用户相关用授权码模式；系统级调用用客户端凭证模式        |
| 只做“入口集成”，不需要用户信息、也不需要调用平台接口     | 可不接入授权接口（按业务自行处理登录） | 若需要平台统一登录体验，建议仍接入客户端授权          |

说明：在量子密信场景中，“用户同意授权”由客户端首次进入应用时弹出授权协议完成；同意后平台生成 code 并按 redirect\_uri 重定向。

### 三、开发前准备

#### 1. 创建自建应用并获取凭证

在开发者后台创建自建应用，完成应用名称、图标、描述等基础信息配置，系统生成 AppId / AppSecret。

安全要求：AppSecret 属高敏信息，必须仅保存在服务端，不允许写入前端或客户端。

#### 2. 配置网页应用能力

在应用能力中启用“网页应用”，并完成入口配置（多端入口、跳转链接、最小版本、外部打开等）。

建议同时规划以下策略：

- 不同端（PC/移动/信创等）是否使用同一入口或不同入口
- 是否需要外部浏览器打开（与业务安全与体验相关）
- 最小客户端版本控制（用于兼容性治理与灰度策略）

#### 3. 配置免登/重定向白名单（如需用户授权登录）

若网页应用需要用户授权登录(授权码模式),需配置免登相关安全项与 redirect\_uri 白名单，确保授权回调可用。

### 四、网页应用开发流程（推荐实践）

#### Step 1: 开发网页应用服务

开发者基于自有技术栈开发网页应用页面与服务端接口，建议满足以下基本要求：

- 使用 HTTPS 访问（建议全链路启用）
- 页面具备登录态管理能力（服务端 session 或 token 体系）
- 能正确处理授权回调（redirect\_uri）与异常提示
- 具备基础的可用性保障与日志审计能力

## Step 2: 客户端授权: 应用授权登录

当业务需要识别用户或获取用户可访问的数据时, 按以下方式接入:

1. 引导授权: 调用 `authorize` 获取 `code`
2. 服务端换取 `token`: 使用 `code` 换取用户授权 `access_token`
3. 获取用户信息: 调用 `userinfo` 获取用户基本信息
4. 处理 `token` 生命周期: 必要时使用 `refresh_token` 刷新

接口参数、示例与错误码处理请参考【应用授权登录】模块

## Step 3: 服务端授权: 应用 `access_token` 调用接口

当网页应用服务端需要调用资源接口 (平台资源或自建应用资源接口) 时, 按以下方式接入:

1. 服务端获取应用 `access_token` (`client_credentials`)
2. 在调用接口时携带 `Authorization: Bearer <access_token>`
3. 实现 `token` 缓存与过期处理策略

接口参数、示例与错误码处理请参考【获取 `access_token`】模块

## Step 4: 联调与测试

建议先将应用发布为“仅开发者可见”进行联调验证, 重点检查:

- 网页入口是否可正常打开 (各端)
- `redirect_uri` 是否可回调 (授权码流程)
- 用户授权同意/拒绝时的页面处理是否符合预期
- `token` 过期与刷新逻辑是否正确
- 接口调用是否符合 `scope` 与权限申请范围

## Step 5: 发布上线

提交应用版本并设置可见范围 (全部成员/部门成员/仅开发者), 按单位内部流程完成审批后上线。

## 五、配置与开发注意事项

### 1. 高敏信息保护

- AppSecret、access\_token、refresh\_token 必须仅存储在服务端
- 禁止在前端代码、URL 参数、日志明文中暴露 token 或密钥

### 2. redirect\_uri 与 state 校验

- redirect\_uri 建议使用 HTTPS，并与平台配置保持一致
- 使用 state 防止 CSRF，需校验回传 state 与发起时一致

### 3. scope 最小化原则

- 仅申请业务所需的 scope
- scope 变更可能导致用户重新授权或触发授权流程调整

## 六、验收清单（上线前建议自查）

- ☐ 多端入口配置正确（PC/移动/信创等）
- ☐ 免登/redirect\_uri 白名单配置正确（如使用授权码模式）
- ☐ code 换 token、userinfo、refresh\_token 逻辑已完成并可用
- ☐ client\_credentials 获取应用 token 并调用资源接口成功
- ☐ token/权限错误码处理完善（invalid\_grant/invalid\_token/invalid\_scope 等）
- ☐ 高敏信息不落前端、不落明文日志

## 七、常见问题与排查（FAQ）

本节整理网页应用接入过程中常见问题与排查建议，便于开发者快速定位问题并恢复业务。

### 1. 打开授权链接提示“该链接无法访问”

可能原因

- 授权请求参数缺失或拼装错误（`client_id`、`redirect_uri`、`scope`、`response_type` 等）

- 应用未具备 `scope` 对应的授权范围权限
- `redirect_uri` 未按要求配置（例如未使用 HTTPS 或不匹配）

排查建议

- 检查 `authorize` 请求参数是否完整、是否 URL 编码正确
- 确认 `scope` 至少包含 `openid`，多个 `scope` 使用空格分隔
- 确认 `redirect_uri` 与平台配置一致，且建议使用 HTTPS

## 2. 用户同意授权后没有进入网页应用，或回调地址没有收到 `code`

可能原因

- `redirect_uri` 配置不正确或未加入白名单
- `redirect_uri` 与发起授权时填写的不一致
- 客户端拦截了非 HTTPS 或不安全跳转

排查建议

- 确认 `redirect_uri` 与后台配置保持一致（包括路径、参数、末尾斜杠）
- 确认已按安全配置要求完成 `redirect_uri` 白名单配置
- 使用服务端日志记录回调请求，确认是否有请求到达

## 3. `code` 换 `token` 返回 `invalid_grant`

可能原因

- `code` 已过期
- `code` 已被使用（`code` 只能使用一次）
- `redirect_uri` 不一致（换 `token` 时的 `redirect_uri` 必须与授权时一致）

排查建议

- 确保收到 `code` 后及时在服务端发起换 `token` 请求
- 确保同一个 `code` 仅使用一次，避免重复提交

- 校验 token 接口请求中的 `redirect_uri` 与授权阶段完全一致

#### 4. 调用 `userinfo` 返回 `invalid_token`

可能原因

- `access_token` 已过期或已失效
- `Authorization` 头格式错误 (Bearer 缺失或多余空格)
- 使用了错误类型的 token (例如混用应用 token 与用户 token)

排查建议

- 确认请求头为 `Authorization: Bearer <access_token>`
- 若 `access_token` 过期, 使用 `refresh_token` 刷新或重新授权
- 明确区分: `userinfo` 需要的是“用户授权 `access_token`”

#### 5. token 接口返回 `invalid_client` / `unauthorized_client`

可能原因

- `client_id` 或 `client_secret` 不正确
- `client_secret` 泄露后被重置, 使用了旧密钥
- 应用未具备对应授权能力

排查建议

- 确认服务端使用的是最新的 AppId / AppSecret
- 如已重置 AppSecret, 确认配置已同步更新
- 检查应用权限与配置是否完整 (尤其是授权相关配置)

#### 6. 返回 `invalid_scope` / `insufficient_scope`

可能原因

- `scope` 参数无效或超出授权范围
- 未申请对应权限, 或申请的 `scope` 与实际调用接口不匹配

排查建议

- 采用最小化 scope 原则，仅申请业务必要的 scope
- 检查应用已获授权范围是否包含请求的 scope
- 若返回 insufficient\_scope，按平台流程申请更高权限

## 7. state 校验失败（疑似 CSRF 风险）

可能原因

- state 未正确保存/回传比对
- 多次并发登录导致 state 被覆盖
- 回调请求被篡改

排查建议

- 每次发起授权时生成新的随机 state，并在服务端保存
- 回调后必须校验 state 一致性，不一致应拒绝继续登录
- 建议将 state 与会话/请求上下文绑定，避免并发覆盖

## 8. 能拿到用户信息，但“可获取的数据范围”不符合预期

可能原因

- scope 申请不足，导致字段缺失或数据不可访问
- 使用了应用 token 调接口而非用户 token（或反之）
- 后端业务侧未按用户身份做权限控制

排查建议

- 根据业务需要补充申请对应 scope，并评估授权范围变更的影响
- 明确区分两类 token：用户授权 token vs 应用 token
- 在业务服务端按用户身份与权限模型做二次校验

## 9. 为什么必须“code 换 token”，不能直接把 token 给前端？

说明

- token 与密钥属于高敏信息，前端/客户端环境不可完全可信

- code 为一次性短期票据，泄露风险更低
- 使用 code 换 token 可将高敏凭证限制在服务端，符合安全最佳实践

### 5.2.2 获取 access\_token

#### 一、流程概述

服务端授权流程包含 2 步：

1. 使用客户端凭证模式获取应用 access\_token
2. 携带 access\_token 调用资源服务器接口

#### 二、Step 1：获取应用 access\_token (client\_credentials)

##### 2.1 请求地址

POST https://<认证服务器域名>/seal/oauth2/token

##### 2.2 请求头

Content-Type: application/x-www-form-urlencoded

##### 2.3 请求参数

| 参数名           | 必选 | 类型     | 说明                         |
|---------------|----|--------|----------------------------|
| grant_type    | 是  | string | 固定值：<br>client_credentials |
| client_id     | 是  | string | 应用 ID                      |
| client_secret | 是  | string | 应用密钥                       |
| scope         | 是  | string | 申请访问资源的 scope              |

##### 2.4 返回示例

```
{  
  "access_token": "ACCESS_TOKEN",  
  "scope": "openid",  
  "token_type": "Bearer",  
  "expires_in": 7199
```

```
}
```

## 2.5 返回参数说明

| 字段名          | 说明              |
|--------------|-----------------|
| access_token | 访问令牌，用于访问受保护资源  |
| token_type   | 令牌类型，通常为 Bearer |
| expires_in   | 有效期（秒）          |
| scope        | 实际授权的权限范围       |

## 三、Step 2: 携带 access\_token 调用资源接口

### 3.1 请求方式

获取 access\_token 后，请求资源服务器接口：

- https://<资源服务器域名>/<接口路径>

### 3.2 请求头

Authorization: Bearer <access\_token>

### 3.3 请求示例

GET https://<资源服务器域名>/example

Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...

## 四、错误处理

### 4.1 token/权限相关错误

- invalid\_scope: 请求的 scope 无效或超出授权范围
- insufficient\_scope: 权限不足，需要申请更高权限
- invalid\_token: token 过期或失效

### 4.2 HTTP 状态码（示例）

- 400: 请求参数错误
- 401: 缺少或无效身份验证
- 403: 权限不足
- 404: 资源不存在

- 500: 服务器内部错误
- 503: 服务不可用

## 五、安全建议

- client\_secret、access\_token 必须仅保存在服务端
- 建议在服务端实现 token 缓存与过期刷新策略（到期前刷新/到期后重取）
- 建议按接口能力最小化申请 scope，避免过度授权

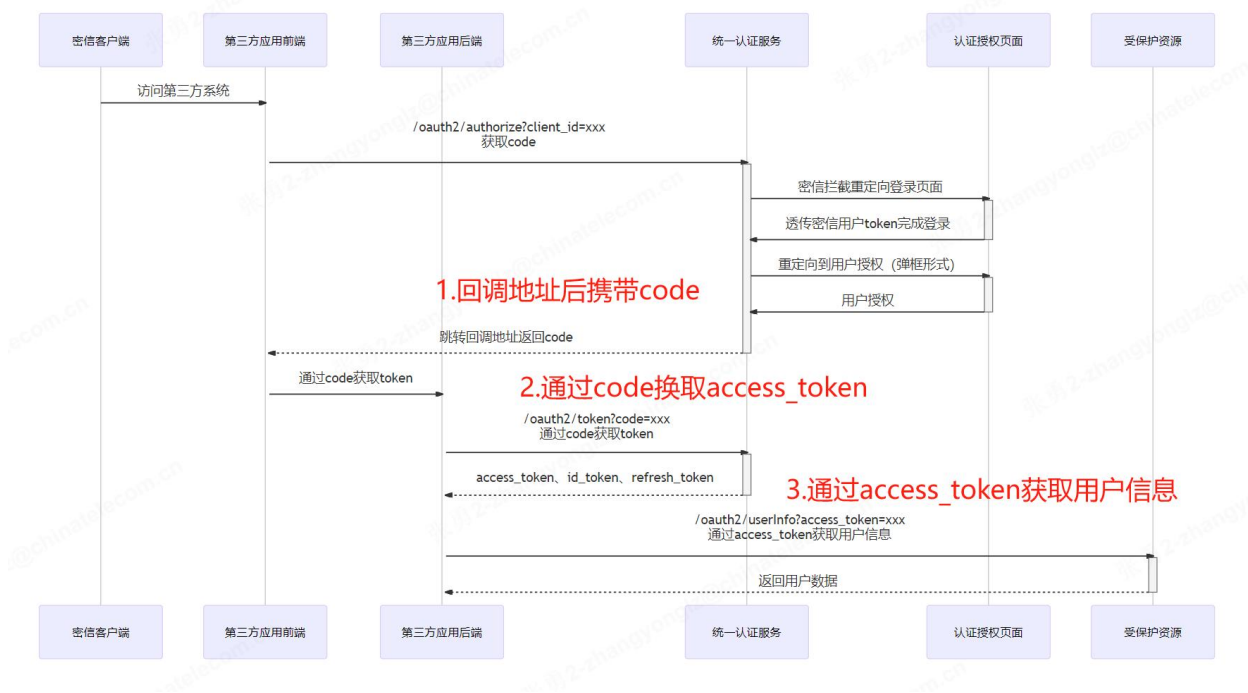
### 5.2.3 应用授权登录

#### 一、流程概述

用户授权流程包含 4 步：

1. 引导用户进入授权流程并获取 code（授权码）
2. 使用 code 换取用户授权 access\_token（以及 refresh\_token、id\_token）
3. 使用授权 access\_token 获取用户基本信息
4. 如有需要，使用 refresh\_token 刷新 access\_token，避免过期

#### 密信客户端-工作台应用接入时序图



## 二、Step 1: 获取 code（用户同意授权）

### 2.1 免登重定向返回

用户同意授权后，平台将重定向至：

`<redirect_uri>?code=<CODE>&state=<STATE>`

code 说明

- code 为一次性票据，每次授权生成的 code 不同
- code 仅可使用一次
- code 有效期较短（未使用将自动过期）

state 说明

- 随机字符串，用于防范 CSRF 攻击，重定向时会原样返回工作台默认值为（）

## 三、Step 2: 使用 code 换取授权 access\_token

安全要求：client\_secret、access\_token 属高敏信息，必须仅保存在服务端，禁止下发或暴露到客户端。

### 3.1 请求地址

POST `https://<认证服务器域名>/seal/oauth2/token`

### 3.2 请求头

Content-Type: `application/x-www-form-urlencoded`

### 3.3 请求参数

| 参数名           | 必选 | 类型     | 说明                         |
|---------------|----|--------|----------------------------|
| grant_type    | 是  | string | 固定值：<br>authorization_code |
| client_id     | 是  | string | 应用 ID                      |
| client_secret | 是  | string | 应用密钥                       |

|              |   |        |                           |
|--------------|---|--------|---------------------------|
| code         | 是 | string | Step 1 获取的授权码             |
| redirect_uri | 是 | string | 与授权请求中使用的 redirect_uri 相同 |

### 3.4 返回示例

```
{  
  "access_token": "ACCESS_TOKEN",  
  "token_type": "Bearer",  
  "expires_in": 3600,  
  "refresh_token": "REFRESH_TOKEN",  
  "id_token": "ID_TOKEN",  
  "scope": "openid profile email"  
}
```

## 四、Step 3: 获取用户基本信息 (userinfo)

### 4.1 请求地址

GET https://<认证服务器域名>/seal/userinfo

### 4.2 请求头

Authorization: Bearer <access\_token>

### 4.3 返回示例

```
{  
  "sub": "5f7174df27e0eb9c6d21436d",  
  "gender": null,  
  "name": null,  
  "birthdate": null,  
  "updated_at": null  
}
```

```
}
```

#### 4.4 字段说明（示例）

- sub: 用户唯一标识
- name: 姓名
- picture: 头像
- email / email\_verified: 邮箱及认证状态
- phone\_number / phone\_number\_verified: 手机号及认证状态
- locale: 区域
- updated\_at: 信息更新时间

#### 4.5 scope 与字段范围

不同 scope 对应可获取的用户信息字段范围：

| scope   | 对应信息                                                                                                                                    |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------|
| address | address                                                                                                                                 |
| email   | email、email_verified                                                                                                                    |
| phone   | phone_number、phone_number_verified                                                                                                      |
| profile | birthdate、family_name、gender、given_name、locale、middle_name、name、nickname、picture、preferred_username、profile、updated_at、website、zoneinfo |

注：后续可扩展自定义 scope。

### 五、Step 4：刷新 access\_token（refresh\_token）

当 access\_token 过期时，可使用 refresh\_token 刷新。refresh\_token 有有效期，失效后需用户重新授权。

#### 5.1 请求地址

POST https://<认证服务器域名>/seal/oauth2/token

#### 5.2 请求头

Content-Type: application/x-www-form-urlencoded

### 5.3 请求参数

| 参数名           | 必选 | 类型     | 说明                         |
|---------------|----|--------|----------------------------|
| grant_type    | 是  | string | 固定值: refresh_token         |
| client_id     | 是  | string | 应用 ID                      |
| client_secret | 是  | string | 应用密钥                       |
| refresh_token | 是  | string | 换 token 时返回的 refresh_token |

### 5.4 返回示例

```
{
  "access_token": "ACCESS_TOKEN",
  "token_type": "Bearer",
  "expires_in": 3600,
  "refresh_token": "REFRESH_TOKEN",
  "id_token": "ID_TOKEN",
  "scope": "openid profile email"
}
```

## 六、常见错误码（认证/授权）

当 HTTP 响应码不为 200 时，可能返回错误信息，例如：

- invalid\_grant: code 无效/过期/已使用
- invalid\_token: token 过期或失效
- invalid\_scope: scope 无效或超出授权范围

详细错误码可参考平台统一错误码表。

## 七、安全建议

- redirect\_uri 建议使用 HTTPS，防止 code 泄露

- AppSecret / access\_token / refresh\_token 严禁出现在前端代码或客户端日志中
- 使用 state 做 CSRF 防护，需校验回传 state 与发起时一致